



INFORMATION RESOURCES USE AND SECURITY POLICY

[Home](#)[ISO Policies, Standards, and Guidelines](#)[INFORMATION RESOURCES USE AND SECURITY POLICY](#)

Table of Contents

- [Purpose](#)
- [Policy Statement](#)
- [Applicability](#)
- [Compliance with State Law](#)
- [Information Security Standards](#)
- [Definitions](#)
- [Relevant Federal and State Statutes and Regulations](#)
- [Supplemental Policies](#)
- [Who Should Know](#)
- [UT Austin Office Responsible Policy](#)
- [Dates Approved or Amended](#)
- [Contact Information](#)
- [Implementation](#)
- [Revision History](#)

Purpose

The Information Resources Use and Security Policy provides The University of Texas at Austin (U. T. Austin) with guidance and defines responsibilities and procedures relating to the operational implementation of the [UT System Information Resources Use and Security Policy \(UTS 165\)](#). For ease of reference both documents share the same organizational structure and a common table of contents.

Title 1 Texas Administrative Code 202.70 (1) states that it is the policy of the state of Texas that information resources residing in the various agencies of State government are strategic and vital assets belonging to the people of Texas. Assets of the university must be available and protected commensurate with their value and must be administered in conformance with federal and state law and UT System [Regents' Rules](#). This Policy provides requirements and guidelines to: establish accountability and prudent and acceptable practices regarding the use and safeguarding of the university's information resources; protect the privacy of personally identifiable information contained in the data that constitutes part of its information resources; ensure compliance with applicable policies and state and federal laws regarding the management and security of information resources; and educate individual Users with respect to the responsibilities associated with use of the university's information resources.

This Policy serves as the foundation for the university's information security program, and provides the Information Security Office the authority to implement policies, practice standards, and/or procedures necessary to implement a successful information security program in compliance with this Policy.

Policy Statement

It is the policy of the university to:

- Protect Information Resources based on risk against accidental or unauthorized disclosure, modification, or destruction and assure the confidentiality, integrity, and availability of university data;
- Appropriately reduce the collection, use, or disclosure of social security numbers contained in any medium, including paper records;
- Apply appropriate physical and technical safeguards without creating unjustified obstacles to the conduct of the business and research of the university and the provision of services to its many constituencies;

Comply with applicable state and federal laws and U.T. System rules governing information resources.

Applicability

This Policy applies to:

- All Information Resources owned, leased, operated, or under the custodial care of U. T. Austin;

- All Information Resources owned, leased, operated, or under the custodial care of third-parties operated on behalf of U. T. Austin; and
- All individuals accessing, using, holding, or managing University Information Resources on behalf of the U. T. Austin.

Compliance with State Law

Information that is collected pursuant or related to the U. T. Austin Information Security Program is subject to [Section 552.139 of the Texas Government Code](#) and is therefore confidential by law.

Accordingly, the university may not withhold information or fail to include information required by this Policy and/or Security Standards to be provided to or included in the U. T. Austin Information Security Program, or for administration of program oversight.

Information Security Standards

UT-IRUSP Standard 1	Information Resources Security Responsibilities and Accountability
UT-IRUSP Standard 2	Acceptable Use of Information Resources
UT-IRUSP Standard 3	Information Security Programs
UT-IRUSP Standard 4	Access Management
UT-IRUSP Standard 5	Administrative/Special Access Accounts
UT-IRUSP Standard 6	Backup and Disaster Recovery
UT-IRUSP Standard 7	Change Management
UT-IRUSP Standard 8	Malware Prevention
UT-IRUSP Standard 9	Data Classification
UT-IRUSP Standard 10	Risk Management
UT-IRUSP Standard 11	Safeguarding Data
UT-IRUSP Standard 12	Security Incident Management
UT-IRUSP Standard 13	Use and Protection of Social Security Numbers
UT-IRUSP Standard 14	Information Services (IS) Privacy
UT-IRUSP Standard 15	Passwords

<u>UT-IRUSP Standard 16</u>	Data Center Security
<u>UT-IRUSP Standard 17</u>	Security Monitoring
<u>UT-IRUSP Standard 18</u>	Security Training
<u>UT-IRUSP Standard 19</u>	Server and Device Configuration and Management
<u>UT-IRUSP Standard 20</u>	Software Licensing
<u>UT-IRUSP Standard 21</u>	System Development and Deployment
<u>UT-IRUSP Standard 22</u>	Vendor and Third-Party Controls and Compliance
<u>UT-IRUSP Standard 23</u>	Security Control Exceptions
<u>UT-IRUSP Standard 24</u>	Disciplinary Actions

Definitions

The following definitions are used within the context of this Policy and all U. T. Austin Standards established by this Policy.

Authentication - a process used to verify one's identity.

Backup - copy of files or applications made to avoid loss of data and facilitate recovery in the event of a system failure or other data loss event.

Category-I Data - also known as Confidential data.

Category-II Data - also known as Controlled data.

Category-III Data - also known as Published data.

Centralized IT - the institutional information technology services and support organization, reporting to the highest-ranking information technology administrator/officer at the university, that supports institutional legacy administrative systems or enterprise resource planning (ERP) systems such as student administration (admissions, financial aid, registration, etc.), financial information systems,

procurement systems, human resource systems, payroll, research administration (grants and contracts), Network Infrastructure, institutional electronic communications, video, library systems, etc.

Change - any addition or removal of, and any modification or update to an Information Resource.

Change Management - process of controlling the communication, approval, implementation, and documentation of modifications to hardware, software, and Procedures to ensure that Information Resources are protected against improper modification before, during, and after system implementation.

Chief Administrative Officer - the highest ranking executive officer at the university. This is the President for the U. T. Austin.

Cloud Computing (Cloud Services) - has the same meaning as "Advanced Internet-based computing service" as defined in [Texas Government Code 2157.007\(a\)](#): "a service that provides network access to a shared pool of configurable computing resources on demand, including networks, servers, storage, applications, or related technology services, that may be rapidly provisioned and released by the service provider with minimal effort and interaction. The term does not include telecommunications service or the act of hosting computing resources dedicated to a single purchaser."

Commodity Server – a system providing commodity services to university affiliates (e.g., web servers, e-mail servers, file servers, database servers, directory servers).

Common Use Infrastructure - an IT facility, network, system, or other Information Resource managed, owned or controlled by U. T. System Institutions that provides services to multiple U. T. Institutions under the auspices of the U. T. System. Examples: shared data centers, the U. T. System Network, the U. T. System Identity Management Federation, TexSIS student information system, UTShare HR/Finance, eCRT certification effort reporting system.

Computing Device - any device capable of sending, receiving, or

storing Digital Data, including but not limited to: computer servers, workstations, desktop computers, laptop computers, tablet computers, cellular/smart phones, personal digital assistants, USB drives, embedded devices, smart watches and other wearable electronic devices, etc.

Confidential Data - one of three data classifications defined within the U. T. Austin [Data Classification Standard](#). The “Confidential” classification applies to data/information that is exempt from unauthorized disclosure under applicable State law, including the Texas Public Information Act, and Federal laws. Confidential Data is also historically referred to as Category-I data.

Controlled Data - one of three data classifications defined within the U. T. Austin [Data Classification Standard](#). The “Controlled” classification applies to information/data that is not generally created for or made available for public consumption, but that is subject to release to the public through request via the Texas Public Information Act or similar State or Federal law. Controlled Data is also historically referred to as Category-II data.

Data - elemental units, regardless of form or media, that are combined to create information used to support research, teaching, patient care, and other University business processes. Data may include but are not limited to: physical media, digital, video, and audio records, photographs, negatives, etc.

Data Center - a facility used to house computer systems and associated components, such as [telecommunications](#) and [storage systems](#).

Decentralized IT - information technology service and support organizations reporting to the heads of business units, departments, or programs that manage or support their own information systems.

Digital Data - the subset of Data (as defined above) that is transmitted by, maintained, or made available in electronic form.

Emergency Change - a change to an Information Resource made in response to unexpected events or circumstances that pose a threat

to the environment or institution, and thereby justify use of expedited change procedures.

Electronic Communication - method used to convey a message or exchange information via Electronic Media instead of paper media. It includes the use of Electronic Mail, instant messaging, Short Message Service (SMS), facsimile transmission, Social Media, and other paperless means of communication.

Electronic Mail (Email) - any message, image, form, attachment, data, or other communication sent, received, or stored within an electronic mail system.

Electronic Media - any of the following:

- electronic storage media including storage devices in computers (hard drives, memory) and any removable/transportable digital storage medium, such as magnetic tape or disk, optical disk, or digital memory card; or
- transmission media used to exchange information already in electronic storage media. Transmission media include, for example, the Internet (wide-open), extranet (using Internet technology to link a business with information accessible only to collaborating parties), leased lines, dial-up lines, private networks, intranet, and the physical movement of removable/transportable electronic storage media.

Guideline - recommended, non-mandatory controls that help support Standards or serve as a reference when no applicable Standard is in place.

Heightened Scrutiny Artificial Intelligence System (HSAI) - an artificial intelligence system that (1) produces outputs with a material legal or similarly significant effect on an individual's access to a university-administered service, including but not limited to benefits eligibility, financial aid, admissions and dismissal, grading, licensing, recruitment, hiring, termination, discipline, or other personnel decisions, student conduct and academic integrity, child welfare, law enforcement, legal analysis or advice, production or evaluation of academic work product, curriculum design, instructional and testing materials, and academic or scientific research, accreditation, and export control; and (2) operates without meaningful human review, or is capable of altering the outcome of such a decision without a human

genuinely considering and exercising independent judgment over that output.

High Impact Information Resources - Information Resources whose loss of confidentiality, integrity, or availability could be expected to have a severe or catastrophic adverse effect on organizational operations, organizational assets, or individuals. Such an event could:

- cause a severe degradation in or loss of mission capability to an extent and duration that the organization is not able to perform one or more of its primary functions;
- result in major damage to organizational assets;
- result in major financial loss; or
- result in severe or catastrophic harm to individuals involving loss of life or serious life threatening injuries.

High Risk Computing Device - a computing device meeting any of the following criteria:

- is located in a public or high-traffic area and is used by a person who has access to Confidential Data;
- is used to create, store, or process Confidential Data or is used within a functional area that handles such data;
- is used by any executive officers or their support staff; or
- contains data that if accessed, changed, or deleted by an unauthorized party could have highly adverse impact on the university.

Based on these criteria, designation of a computing device as being “High Risk” is made by the Information Resource Owner in consultation with the U. T. Austin Chief Information Security Officer. In event of disagreement regarding the designation of a computing device as being “High Risk,” the Information Resource Manager will work to mediate the disagreement with all parties.

Information - Data organized, formatted and presented in a way that facilitates meaning and decision making. All information is comprised of data.

Information Resources - any and all computer printouts, online display devices, mass storage media, and all computer-related activities involving any device capable of receiving email, browsing Web sites, or otherwise capable of receiving, storing, managing, or transmitting data including, but not limited to, mainframes, servers,

Network Infrastructure, personal computers, notebook computers, hand-held computers, pagers, distributed processing systems, network attached and computer controlled medical and laboratory equipment (i.e. embedded technology), telecommunication resources, network environments, telephones, fax machines, printers and service bureaus. Additionally, it is the procedures, equipment, facilities, software, and Data that are designed, built, operated, and maintained to create, collect, record, process, store, retrieve, display, and transmit information.

Information Resources Custodian (Custodian) - an individual, department, Institution, or third-party service provider responsible for supporting and implementing Information Resources Owner defined controls to Information Resources. Custodians include Information Security Administrators, institutional information technology/systems departments, faculty or staff, vendors, and any third-party acting as an agent of or otherwise on behalf of an Institution.

Information Resources Manager (IRM) - the executive responsible for Information Resources across the whole of the institution as defined in [Chapter 2054, Subchapter D, Texas Government Code](#). This is the Chief Information Officer at U.T. Austin.

Information Resources Owner (Owner) - the manager or agent responsible for the business function that is supported by the Information Resource or the individual upon whom responsibility rests for carrying out the program that uses the resources. The Owner is responsible for establishing the controls that provide the security, as well as authorizing access to the Information Resource. The Owner of a collection of information is the person responsible for the business results of that system or the business use of the information. Where appropriate, ownership may be shared. Note: In the context of this Policy and associated Standards, Owner is a role that has security responsibilities assigned to it by Texas Administrative Code (TAC) 202.72. It does not imply legal ownership of an Information Resource. All University Information Resources are legally owned by U. T. Austin or U. T. System.

Information Security Administrator - a departmental employee, designated by management, who assists with information security

tasks as described in [UTS165 Standard 1 - Information Resources Security Responsibilities and Accountability](#). The Information Security Administrator is also historically known as the IT Security Custodian.

Information Security Program - the Policies, Standards, Procedures, Guidelines, elements, structure, strategies, objectives, plans, metrics, reports, resources, and services adopted for the purpose of securing University Information Resources.

Information System - an interconnected set of Information Resources under the same direct management control that shares common functionality. An Information System normally includes hardware, software, Network Infrastructure, information, data, applications, communications, and people.

Information Technology (IT) - the hardware, software, services, supplies, personnel, facilities, maintenance, and training used for the processing of Data and telecommunications.

Inherent Impact - the degree of Impact (High, Moderate, or Low) that could result if Information Resources were subjected to unauthorized access, use, disclosure, disruption, modification, or destruction.

Institution - U. T. System Administration, UTIMCO, or any individual University that is part of the University of Texas System. Same as University.

Integrity - the accuracy and completeness of information and assets, and the authenticity of transactions.

Internet - a global system interconnecting computers and public computer networks. The computers and networks are owned separately by a host of organizations, government agencies, companies, and colleges.

Lead Researcher - the person engaged in the conduct of Research with primary responsibility for stewardship of Research Data on

behalf of an Institution. For the purpose of this Policy and associated Standards, the term is synonymous with Principal Investigator.

Local Area Network (LAN) - a data communications network spanning a limited geographical area, a few miles at most. It provides communication between computers and peripherals at relatively high data rates and relatively low error rates.

Low Impact Information Resources - Information resources whose loss of confidentiality, integrity, or availability could be expected to have a limited adverse effect on organizational operations, organizational assets, or individuals. Such an event could:

- cause a degradation in mission capability to an extent and duration that the organization is able to perform its primary functions, but the effectiveness of the functions is noticeably reduced;
- result in minor damage to organizational assets;
- result in minor financial loss; or
- result in minor harm to individuals.

Malware - a computer program that is inserted into an Information System, usually covertly, with the intent of compromising the confidentiality, integrity, or availability of data, applications, or operating system, or of otherwise annoying or disrupting the User or Information System. Malware (malicious software) may attach itself to a file or application; deliver a payload without the knowledge or permission of the User; insert itself as a service or process to intercept sensitive information and/or keystrokes and deliver it to a third-party; or compromise the User's computer and use it to launch compromises against other computers, among other capabilities. Viruses, worms, Trojan horses, spyware, adware, ransomware, and any code-based entity that infects a host are examples of malicious software.

Mission Critical Information Resources - Information Resources defined to be essential to U. T. Austin's ability to meet its instructional, research, patient care, or public service missions. The loss of these resources or inability to restore them in a timely fashion would result in the failure of U. T. Austin's operations, inability to comply with regulations or legal obligations, negative legal or financial impact, or endanger the health and safety of faculty, students, staff, and

patients. Mission Critical Information Resources include but are not limited to:

- Information Systems managing Confidential Data;
- Common Use Infrastructures;
- Institutional Network and Data Center Infrastructure;
- Identity and Access Management Systems, such as single-sign-on or other applications required to enable access to other critical systems;
- Administrative systems (e.g., HR, Finance, Payroll, Credit Card Data Environments (CDE), student/patient enrollment and billing, etc.);
- Student information systems;
- Patient care and life-support systems, etc.

Mission Critical Information Resources Staff - IT Staff generally responsible for the support and operation of Mission Critical Information Resources. These staff will typically have additional security controls applied to their roles given that their access and privilege levels can represent a more significant risk to the university.

Moderate Impact Information Resources - Information Resources whose loss of confidentiality, integrity, or availability could be expected to have a serious adverse effect on organizational operations, organizational assets, or individuals. Such an event could:

- cause a significant degradation in mission capability to an extent and duration that the organization is able to perform its primary functions, but the effectiveness of the functions is significantly reduced;
- result in significant damage to organizational assets;
- result in significant financial loss; or
- result in significant harm to individuals that does not involve loss of life or serious life threatening injuries.

Multi-factor Authentication - a process for verifying a person's identity that requires use of two of the following three elements:

- a. something the person knows, such as a password;
- b. something the person has, such as a token or smart card; or
- c. a unique characteristic of the person, such as a fingerprint.

Network Infrastructure - the distributed hardware and software (i.e., cabling, routers, switches, wireless access points, access methods, and protocols), information, and integrating components that allow institutional network hosts to communicate with one another and

enable the administrative, learning, research, and health care missions of the Institution.

Non-University Owned Computing Device - any device that is capable of receiving, transmitting, and/or storing electronic data, and that is not owned, leased, or under the management of an Institution, including personally owned devices.

Owner – See Information Resources Owner.

Password - a string of characters used to verify or "authenticate" a person's identity. Passphrases and personal identification numbers (PIN) serve the same purpose as a Password.

Personally Identifiable Information (PII) - information that alone or in conjunction with other information identifies an individual. PII includes, but is not limited to: an individual's name; a Social Security number; a date of birth; a government-issued identification number; a mother's maiden name; unique biometric data (including an individual's fingerprint, voice print, and retina or iris image); a unique electronic identification number, address, or routing code; or a telecommunication access device.

Policy - high level statements of intent relating to the protection of Information Resources across an organization (e.g., the U. T. Austin). Compliance with a Policy is mandatory.

Portable Computing Device - any easily movable device capable of receiving, transmitting, and/or storing data. These include, but are not limited to: notebook computers, handheld computers, tablets (e.g., iPads, etc.), PDAs (personal digital assistants), pagers, smartphones (e.g., iPhones, etc.), Universal Serial Bus (USB) drives, memory cards, external hard drives, data disks, CDs, DVDs, and similar storage devices.

Practice - customary actions, which may or may not be documented, taken to accomplish information security tasks.

Procedure - step by step instructions to assist information security and technology staff, Custodians, and Users in implementing various policies, standards, and guidelines.

Published Data - one of three data classifications within the U. T. Austin [Data Classification Standard](#). This classification includes data/information made available to the public through posting to public websites or distribution through email, social media, print publications, or other media. Published Data is also historically referred to as Category-III data.

Remote Access - access to University Information Resources that originates from a Remote Location.

Remote Location - a location outside the physical boundary of the university (inclusive of university leased/rented properties and locations within the university's compliance environment).

Residual Risk - the risk (Low, Moderate, or High) that remains after security controls have been applied.

Research - systematic investigation designed to develop and contribute to knowledge and may include all stages of development, testing, and evaluation.

Researcher - Lead Researchers, faculty, staff, graduate students, postdoctoral fellows, residents, and visiting/affiliated scientists who are engaged in or responsible for Research activities.

Risk - a function of the likelihood that a threat will exploit a vulnerability and the resulting impact to University missions, functions, image, reputation, assets, or constituencies if such an exploit were to occur.

Scheduled Change - a change to an Information Resource made under normal working conditions following formally defined change

control processes as defined in [UT-IRUSP Standard 7 - Change Management](#).

Security Incident - an event that results in unauthorized access, loss, disclosure, modification, disruption, or destruction of Information Resources whether accidental or deliberate.

Server - a program that provides services to (programs on) other devices. A computer running a server program is frequently referred to as a server, though it may also be running other client (and server) programs.

Social Media - a forum or media for social interaction, using highly accessible and scalable communication techniques. Examples include but are not limited to wikis (e.g., Wikia, Wikimedia); blogs and microblogs (e.g., Blogger, Twitter); content communities (e.g. Flickr, YouTube); social networking sites (e.g., Facebook, MySpace, LinkedIn); virtual game worlds; and virtual communities (e.g., SecondLife)

Standards - specific mandatory controls that are components of this Policy or the U. T. Austin Information Security Program.

State Record - a document, book, paper, photograph, sound recording, or other material, regardless of physical form or characteristic, made or received by a state department or institution according to law or in connection with the transaction of official state business.

Strong Password - a Password constructed so that another User cannot easily guess it and so that a “hacker” program cannot break it within a reasonable amount of time. It typically consists of a minimum number of positions in length and contains a combination of alphabetic, numeric, or special characters.

Two-factor Authentication - a process for verifying a person’s identity that requires use of two of the following three elements:

- a. something the person knows, such as a password;
- b. something the person has, such as a token or smart card; or

c. a unique characteristic of the person, such as a fingerprint.

University - U. T. System Administration, UTIMCO, or any of the academic Institutions, or health science centers, or other entities as from time to time may be assigned by specific legislative act to the governance, control, jurisdiction, or management of U. T. System that comprise The University of Texas System. Same as Institution.

University of Texas System (U. T. System) - the academic institutions and health science centers in The University of Texas System, plus U. T. System Administration and UTIMCO.

University of Texas System Administration (U. T. System Administration) - the central administrative offices that provide oversight and coordination of the activities of U. T. System and its Institutions.

University of Texas System Data (University Data) - All Data or Information held on behalf of U. T. System and its Institutions created as a result of and/or in support of U. T. System business, or residing on U. T. System Information Resources, including paper records.

U. T. System Shared Data Center - any data center governed by the U. T. Shared Data Center (SDC) group on behalf of the U. T. System including the **Arlington Data Center (ARDC) and the Houston Data Center (HDC)**.

U. T. Austin Information Security Program – the U. T. Austin policies, standards, procedures, elements, structure, strategies, objectives, plans, metrics, reports, resources, and services that establish requirements to provide for program oversight.

User - an individual, automated application, or process that is authorized by the Owner to access the resource, in accordance with Federal and State law, university policy, and the Owner's procedures and rules. The User has the responsibility to (1) use the resource only for the purpose specified by the Owner, (2) comply with controls established by the Owner, and (3) prevent the unauthorized disclosure of Confidential Data. A user is any person who has been

authorized by the Owner of the information to read, enter, or update that information.

UTIMCO - The University of Texas Investment Management Company that manages U. T. System's investment assets.

Vendor - any third-party that contracts with U. T. Austin to provide goods and/or services to U. T. Austin.

Relevant Federal and State Statutes and Regulations

[Family Educational Rights and Privacy Act \(FERPA\), 20 U.S.C. § 1232g, and all regulations adopted to implement FERPA.](#)

[Health Insurance Portability and Accountability Act of 1996 \(HIPAA\), Public Law 104-191, and all regulations adopted to implement HIPAA.](#)

[Health Information Technology for Economic and Clinical Health Act, \(HITECH\) Act of 2009, and all regulations adopted to implement HITECH.](#)

[Federal Privacy Act of 1974 \(Section 7 of Pub. L. 93-579 in Historical Note\), 5th U.S.C. § 552a](#)

[Social Security Act, 42 U.S.C. §§ 408\(a\)\(8\) and 405\(c\)\(2\)\(C\)\(viii\)\(I\).](#)

[Gramm-Leach-Bliley Act \(GLBA\).](#)

[Texas Government Code Section 2054.121](#)

[Texas Education Code Section 65.31](#)

[Texas Business and Commerce Code Chapter 521](#)

[Texas Government Code Section 559.003](#)

[Texas Administrative Code, Title 1, Part 10, Chapter 202, Subchapter C, §§202.1-202.4, 202.70-202.76](#)

Supplemental U. T. Austin Policies, Standards, Guidelines, Procedures, and Forms

[Acceptable Use Policy](#)

[Acceptable Use Policy Acknowledgement Form](#)

[Digital Millennium Copyright Act](#)

[Data Classification Standard](#)

[Minimum Security Standards for Application Development and Administration](#)

[Minimum Security Standards for Data Stewardship](#)

[Minimum Security Standards for Merchant Payment Card Processing](#)

[Minimum Security Standards for Systems](#)

[Data Encryption Guidelines](#)

[Network Monitoring Guidelines](#)

[Change Management Process](#)

[Coding Checklists for Application Developers](#)

[Copyright Violations](#)

[Server Security Checklists for System Administrators](#)

[Security Exception Reporting](#)

[University Login Banner](#)

Who Should Know

All individuals accessing, managing, or possessing U. T. Austin Information Resources including U. T. Austin staff, faculty, and students, as well as Vendors and contractors providing services on behalf of U. T. Austin and other third-party contractors.

U. T. Austin Office Responsible for Policy

The University of Texas at Austin Chief Information Security Officer

Cam Beasley

Telephone Number: 512-475-9242

Email: security@utexas.edu

Dates Approved or Amended

Approved: September 15, 2005

Amended: July 16, 2015

Refer to [Revision History](#) for more details related to changes of this policy.

Contact Information

Questions or comments about this policy should be directed to:

security@utexas.edu.

Implementation

This Policy is based on public policy and privacy issues and not on convenience or past practices. Nevertheless, the university recognizes the financial burdens and the potentially disruptive nature of securing, reprogramming, and immediate conversions of business, research, and information systems.

Nothing in this Policy is intended to prohibit or restrict the collection, use, and maintenance of Confidential data as required or permitted by applicable law; to create unjustified obstacles to conduct the business of the university and the provision of services to its many constituencies; or to negatively affect the university's commitment to engage in high-quality, innovative research that entails the discovery, retention, dissemination, and application of knowledge in compliance with university policy and state and federal laws and regulations.

Some of the requirements of this Policy have immediate compliance dates and others have delayed compliance dates. The university should implement those requirements with delayed compliance dates in a steady and purposeful manner so that they are fully implemented no later than the specified respective compliance dates.

The university shall establish priorities for all systems, processes, and research projects that are out of compliance and shall establish a plan for remediating them.

UT-IRUSP Standard 1: Information Resources Security Responsibilities and Accountability

1.1 Designation of Responsibility. U. T. Austin must have designated and documented roles and responsibilities for the information security function.

1.2 Chancellor. The Chancellor shall:

1.2.1 designate an individual to serve as U. T. System Chief Information Security Officer;

1.2.2 budget sufficient resources to fund ongoing information security remediation, implementation, and compliance activities that reduce compliance Risk to an acceptable level; and

1.2.3 ensure that appropriate corrective and disciplinary action is taken in the event of noncompliance.

1.3 Chief Administrative Officers. The U. T. Austin President shall:

1.3.1 ensure the Institution's compliance with this Policy and associated Standards;

1.3.2 designate an individual to serve as the U. T. Austin Chief Information Security Officer (CISO) who shall:

1.3.2.1 serve in the capacity as required by 1 Texas Administrative Code 202.71 (b) with authority for the entire Institution;

1.3.2.2 report to the President or to a senior executive, other than the Chief Information Officer or Information Resources Manager, who reports to the President; and

1.3.2.3 have a dotted line reporting relationship to the U. T. Austin Compliance Officer and the U. T. System Chief Information Security Officer;

1.3.3 budget sufficient resources to fund ongoing information security remediation, implementation, and compliance activities (e.g., staffing, training, tools, and monitoring activities) that reduce compliance Risk to documented acceptable levels;

1.3.4 approve the U. T. Austin Information Security Program; and

1.3.5 ensure appropriate corrective and disciplinary action is taken in the event of noncompliance.

1.4 Information Resources Manager. The IRM shall:

1.4.1 be part of the institution's executive management and report directly to a person with a title functionality equivalent to executive leadership (e.g. President, Provost, Chief Business Officer);

1.4.2 implement security controls for the entire institution in accordance with the UT Austin Information Security Program developed by the Chief Information Security Officer;

1.4.3 review and approve or disallow the purchase or deployment of all new Information Systems or services (infrastructure, on-premise applications, hosted or cloud services/applications, Internet of Things (IoT) devices);

1.4.4 ensure all assets (e.g., devices, applications, and vendor products) used by the institution are cataloged and maintained in a central inventory;

1.4.5 establish visibility (e.g., configuration management) into all assets used by the institution in a manner that does not interfere with the performance of the asset; and

1.4.6 operationalize an institution-wide system management practice based on the UT Austin Information Security Program and corresponding standards for vulnerability management that ensures institutional accountability and report adherence to those standards to senior institution leadership and UT System Administration on a regular basis using a method provided by UT System Administration.

1.5 The U. T. System Chief Information Security Officer shall:

1.5.1 provide leadership, strategic direction, and coordination for the U. T. System-wide Information Security Program including issuing of Policies, Standards, Procedures, and Guidelines;

1.5.2 chair and hold meetings of the U. T. System CISO Council at least quarterly;

1.5.3 develop and oversee the U. T. System-wide Information Security Compliance Program;

1.5.4 provide guidance relating to Institutional and Common Use Infrastructures Information Security Programs regarding organizational duties and responsibilities, covered activities, authority to act, terminology definitions, standard methodologies, and minimum Standards;

1.5.5 define the Risk management process to be used for U. T. System information security Risk management activities, and ensure performance of Risk assessment for system-wide systems that will process or store Confidential Data;

1.5.6 explore and recommend the acquisition of cybersecurity tools, resources, and services that can be utilized by multiple U. T. Institutions and for ways to share expertise among Institutions;

1.5.7 establish reporting requirements, metrics, and timelines and monitor effectiveness of security strategies at each Institution;

1.5.8 apprise the Chancellor, the U. T. System Executive Compliance Committee, and the Board of Regents on the status and effectiveness of the Information Security Compliance Programs;

1.5.9 oversee and/or monitor deployment of information security initiatives funded or sponsored through the U. T. System, and manage contracts with service providers;

1.5.10 establish processes for assessing information security proposals for U. T. System sponsorship, and oversee procurements; and

1.5.11 appoint an Information Security Officer for Common Use Infrastructures.

1.6 Information Security Officer for Common Use Infrastructures. The Information Security Officer for Common Use Infrastructures is responsible for defining, implementing, and managing an Information Security Program encompassing the U. T. System Common Use Infrastructures in accordance with requirements of the U. T. System-wide Information Security Program and shall:

1.6.1 develop and maintain a current and comprehensive Information Security Program, that includes Risk assessment, metrics, action plans, training plans, monitoring plans, and adoption of Policies, Standards, Procedures, and/or Guidelines as needed;

1.6.2 coordinate with Institutional Information Security Officers, Information Resource Managers, facilities management, and

governance groups to ensure appropriate Policies, Standards, Procedures, and/or Guidelines are established, and responsible parties are assigned;

1.6.3 monitor the effectiveness of security controls and submit required reports to the U. T. System Chief Information Security Officer; and

1.6.4 serve as a member of the U. T. System Chief Information Security Officer Council, and perform other tasks similar in nature to an Institutional Information Security Officer.

1.7 U. T. Austin Chief Information Security Officer (CISO). The U. T. Austin Chief Information Security Officer is the individual responsible for an U. T. Austin Information Security Program and shall:

1.7.1 work in partnership with the university community, constituency groups, and leadership to establish effective and secure processes and information systems and to promote information security as a core Institutional value;

1.7.2 provide information security oversight for all Centralized and Decentralized IT Information Resources;

1.7.3 develop and maintain a current and comprehensive Information Security Program, that includes Risk assessment, action plans, training plans, monitoring plans, and specific Risk mitigation strategies to be used by Owners and Custodians of Mission Critical Information Resources to manage identified Risks;

1.7.4 develop Institutional Policies, Standards, Procedures, and/or Guidelines to ensure that the protection of Information Resources is considered during the development or purchase of new computer applications or services;

1.7.5 develop or adopt a Data Classification Standard that conforms or maps to [UTS165, Standard 9](#);

1.7.6 coordinate Risk assessments required by U. T. System to be reported to the U. T. System Executive Compliance Committee or Board of Regents, and ensure that annual information security Risk assessments are performed and documented by Owners of Mission Critical Information Resources and Information Resources containing Confidential Data in accordance with [UT-IRUSP Standard 10 – Risk Management](#);

1.7.7 ensure that each Owner of Mission Critical Information Resources has designated an Information Security Administrator (ISA);

1.7.8 establish an Institutional Information Security Working Group composed of ISAs (ISA Working Group) and convene meetings at least quarterly;

1.7.9 approve and document any exceptions to information security Policies or Standards, other than [UT-IRUSP Standard 2 – Acceptable Use of Information Resources](#), within the Institution in accordance with [UT-IRUSP Standard 23 – Security Control Exceptions](#);

1.7.10 document and justify, in collaboration with the Owners, exceptions to specific elements of the program required due to circumstances within a specific organizational unit(s) within an Institution, and include such exceptions in the annual report to the Chief Administrative Officer;

1.7.11 establish reporting requirements, metrics, and timelines, and monitor effectiveness of security strategies implemented in both Centralized and Decentralized IT;

1.7.12 evaluate effectiveness of information security controls and practices (e.g., using active and passive methods) and perform, at a minimum, an annual vulnerability assessment of Information Resources maintained in both Centralized and Decentralized IT and track implementation of any remediation required as a result of the assessment;

1.7.13 ensure that an annual external network penetration test is performed and track implementation of needed Risk remediation;

1.7.14 specify and require use of appropriate security software such as anti-Malware, firewall, configuration management, and other security related software on Computing Devices owned, leased, or under the custody of any department, operating unit, employee, or other individual providing services to the Institution;

1.7.15 establish and communicate security configuration requirements and Guidelines;

1.7.16 ensure Computing Devices are administered by appropriately trained staff and in accordance with Policies, Standards, and Procedures;

- 1.7.17** review the security requirements, specifications, and third-party Risk assessments of any new computer applications or services that receive, maintain, and/or share Confidential Data;
- 1.7.18** approve security requirements for the purchase of Information Technology hardware, software, and systems development services;
- 1.7.19** ensure all employees receive periodic information security training appropriate to the security role (such as Owner or ISA) of the employee, including high-level information security awareness training as part of each employee's first-time compliance training;
- 1.7.20** communicate instances of noncompliance to appropriate administrative officers for corrective, restorative, and/or disciplinary action;
- 1.7.21** investigate Security Incidents and inform the Chief Administrative Officer of incidents posing significant Risk to individuals, the Institution, or other organizations;
- 1.7.22** report Significant Information Security Incidents, as defined by the [U. T. System Security Incident Reporting Requirements](#), to the U. T. System CISO;
- 1.7.23** participate in the U. T. System CISO Council meetings, workgroups, and related activities;
- 1.7.24** report to the U. T. System CISO in accordance with Program reporting guidance and metrics;
- 1.7.25** provide updates to the U. T. Austin Executive Compliance Committee regarding information security Risks and issues; and
- 1.7.26** provide a report, at least annually, to the Chief Administrative Officer with copies to the U. T. Austin Chief Information Officer and Compliance Officer and the U.T. System Chief Information Security Officer on the status and effectiveness of Information Resources security controls for the whole Institution including, at minimum: (a) progress toward information security milestones; (b) updates on ongoing information security initiatives; (c) security incidents or data breaches including impact and resolution; (d) compliance with applicable information security policies, standards, and statutory requirements including Texas Administrative Code (TAC) 202; (e) results of information security assessments and audits; and (f) changes in the information security risk landscape and planned responses.

1.8 Department Heads and Lead Researchers. Department Heads and Lead Researchers at each U. T. Austin shall classify and appropriately secure Data under their control including Data held in relation to subcontracts for projects in which the prime award is at another Institution or agency.

1.9 Information Resources Owners. For Information Resources and Data under their authority, Owners shall:

1.9.1 grant access to Information Systems and Data;

1.9.2 control and monitor access to Data based on Data sensitivity and Risk;

1.9.3 classify Data based on the U. T. Austin Data Classification Standard;

1.9.4 conduct Risk assessments that identify the Information Resources under their authority and the level of Risk associated with the Information Resources and the vulnerabilities, if any, to the U. T. Austin information security environment;

1.9.5 define, recommend, and document acceptable Risk levels for Information Resources and Risk mitigation strategies;

1.9.6 document and justify, in collaboration with the U. T. Austin CISO, any exceptions to specific program requirements due to extenuating circumstances within the Owner's area of responsibility;

1.9.7 ensure that Data is securely backed up in accordance with Risk management decisions;

1.9.8 ensure that Data is maintained in accordance with the applicable University records retention schedule and Procedures;

1.9.9 provide documented permission and justification for any User who is to store Confidential University Data on a Portable Computing Device or a Non-University Owned Computing Device;

1.9.10 ensure that High Risk Computing Devices and Confidential Data are encrypted in accordance with requirements specified in [UT-IRUSP Standard 11 - Safeguarding Data](#);

1.9.11 ensure that Information Resources under their authority are administered by qualified Information Resources Custodians;

1.9.12 ensure that a Risk assessment is performed prior to purchase of any software that has not been previously assessed by the

Institution for use under similar circumstances;

1.9.13 ensure that a third-party Risk assessment is performed prior to purchase of Vendor services that involve hosting or accessing University Data; and

1.9.14 ensure that contracts involving products or services that impact Information Resources contain information security language appropriate to the Risk.

1.10 Owner of Mission Critical Information Resources. For Information Resources under the Owner's authority, the Owner shall:

1.10.1 designate an individual to serve as an Information Security Administrator (ISA) to implement information security Policies and Procedures and to report incidents to the U. T. Austin Chief Information Security Officer;

1.10.2 provide for appropriate training for ISAs to ensure effective security Practices;

1.10.3 perform an annual information security Risk assessment that identifies Information Resources, levels of associated Risk, and any vulnerabilities to those Information Resources;

1.10.4 define, recommend, and document acceptable Risk levels for Information Resources and Risk mitigation strategies as needed; and

1.10.5 adopt a disaster recovery plan for Information Resources and ensure testing is performed in accordance with the requirements of [UT-IRUSP Standard 6 - Backup and Disaster Recovery](#).

1.11 Information Resources Custodians. Information Resources Custodians shall:

1.11.1 implement approved Risk mitigation strategies and adhere to information security Policies and Procedures to manage Risk levels for Information Resources under their care;

1.11.2 implement monitoring controls for detecting and reporting incidents;

1.11.3 control and monitor access to Information Resources under the Custodian's care based on sensitivity and Risk;

1.11.4 implement and adhere to approved Institutional Change Management processes to ensure secure, reliable, and stable operations;

1.11.5 encrypt High Risk Computing Devices and Confidential Data in accordance with requirements specified in [UT-IRUSP Standard 11 - Safeguarding Data](#);

1.11.6 provide appropriate technical training to employees providing Information Technology, security, help-desk, or technical support for Information Resources under their responsibility; and

1.11.7 ensure that technical staff under their authority are qualified to perform their assigned duties.

1.12 Information Security Administrator. Information Security Administrators shall:

1.12.1 implement and comply with all IT Policies and Procedures relating to assigned Information Systems;

1.12.2 assist Owners in performing annual information security Risk assessments;

1.12.3 report general computing and Security Incidents to the U. T. Austin Chief Information Security Officer;

1.12.4 as a member of the ISA Work Group, assist the U. T. Austin Chief Information Security Officer in developing, implementing, and monitoring the Information Security Program, and in establishing reporting guidance, metrics, and timelines for the U. T. Austin Chief Information Security Officer to monitor effectiveness of security strategies; and

1.12.5 report at least annually to the U. T. Austin Chief Information Security Officer about the status and effectiveness of Information Resources security controls.

1.13 Institutional Office with Designated Responsibility for Account Management. Each office within the U. T. Austin responsible for account management shall manage accounts in accordance with this Policy and all other applicable U. T. Austin information security Policies, Standards, and Procedures.

1.14 Institutional Office Designated with Responsibility for Network Infrastructure. Each office so designated shall be responsible for:

1.14.1 configuring and managing network resources in accordance with this Policy and all other applicable U. T. Austin information security Policies, Standards, and Procedures;

1.14.2 segmenting the U. T. Austin network physically or logically to reduce the scope of potential exposure of Information Resources in the event of a Security Incident;

1.14.3 separating Internet facing applications from internal applications;

1.14.4 maintaining appropriate access to the Network Infrastructure in accordance with this Policy and all other applicable U. T. Austin information security Policies, Standards, and Procedures;

1.14.5 managing, testing, and updating operating systems and applications for network equipment for which it is responsible; and

1.14.6 approving all access methods, installation of all network hardware connected to the local-area network and methods and requirements for attachment of any Non-U. T. Austin Owned Computer Systems or Devices to the U. T. Austin network.

1.15 Institutional Office Charged with Supporting Information Resources. The offices so designated shall be responsible for:

1.15.1 formalizing best Practice Change Management processes into Practice Standards;

1.15.2 requiring compliance from all individuals who manage Information Systems or applications; and

1.15.3 providing support, guidance, and problem resolution to Owners, including Department Heads and Lead Researchers, and Users with respect to this Policy and applicable Standards, Policies, and Procedures.

1.16 Users.

1.16.1 All Users must comply with this Policy. Users who fail to comply are subject to disciplinary action in accordance with [UT-IRUSP Standard 24 – Disciplinary Actions](#).

1.16.2 All Users who are University employees, including student employees, or who are otherwise serving as an agent or are working on behalf of the University, must formally acknowledge and comply with the Institution's Acceptable Use Policy as directed in [UT-IRUSP Standard 2 – Acceptable Use of Information Resources](#).

UT-IRUSP Standard 2: Acceptable Use of Information Resources

2.1 Acceptable Use Policy Requirement. U. T. Austin must adopt and incorporate for all purposes the [U. T. System Acceptable Use Policy](#) model.

INFORMATION RESOURCES ACCEPTABLE USE AND SECURITY POLICY AGREEMENT	
All individuals granted access to or use of System Information Resources must be aware of and agree to abide by the following acceptable use requirements:	
Definitions	• University: The University of Texas at Austin. • System: The University of Texas System. • University Information Resources: All computer and telecommunications equipment, software, data, and media, owned or controlled by University or maintained on its behalf. • University Data: All data or information held on behalf of University, created as result and/or in support of University business, or residing on University Information Resources, including paper records. • Confidential Data or Confidential Information: All University Data that is required to be maintained as private or confidential by applicable law. • User: Any individual granted access to University Information Resources.
General	• University Information Resources are provided for the purpose of conducting the business of University and/or System. However, Users are permitted to use University Information Resources for use that is incidental to the User’s official duties to University or System (Incidental Use) as permitted by this policy. • Users who are University employees, including student employees, or who are otherwise serving as an agent or are working on behalf of the University have no expectation of privacy regarding any University Data they create, send, receive, or store on University owned computers, servers, or other information resources owned by, or held on behalf, of University. University may access and monitor its Information Resources for any purpose consistent with University’s duties and/or mission without notice. • Users have no expectation of privacy regarding any University Data residing on personally owned devices, regardless of why the Data was placed on the personal device. • All Users must comply with applicable University and System Information Resources Use and Security policies at all times.

- All Users must comply with the policy on [Prohibited Technology and Covered Applications](#).
- Users shall never use University Information Resources to deprive access to individuals otherwise entitled to access University Information; to circumvent University computer security measures; or, in any way that is contrary to the University's mission(s) or applicable law.
- Users must not interfere with the activities of others or use a disproportionate share of information resources. Examples of inappropriate use of resources are shown below. These actions frequently result in complaints and subsequent disciplinary action.
 - Sending an unsolicited message(s) to a large number of recipients (known as "spamming the network").
 - Consuming an unauthorized disproportionate share of networking resources (e.g., misuse of peer-to-peer applications).
 - Deliberately causing any denial of service, including flooding, ICMP attacks, or the unauthorized automated use of a service intended solely for human interaction.
- Use of University Information Resources to intentionally access, create, store, or transmit sexually explicit materials is prohibited unless such use is required as part of the User's official duties as an employee of University and is approved in writing by the President or a specific designee. Viewing, accessing, storage, and/or transmission of sexually explicit materials as Incidental Use is prohibited.
- Users should report misuse of University Information Resources or violations of this policy. How an incident is reported depends upon the nature of the incident:
 - If Users believe that their personal safety is threatened, they may call UT Police, 471-4441.
 - For others incidents, Users should contact the Information Security Office at security@utexas.edu or the UT Austin compliance hotline (via helpline@compliance.utexas.edu or 1-877-888-0002).
 - For reporting problems with "spam" or unsolicited mail, Users may notify the Internet service provider (ISP) from which the mail was sent.

Confidentiality
& Security of
Data

- Users shall access University Data only to conduct University business and only as permitted by applicable confidentiality and privacy laws. Users must not attempt to access data on systems they are not expressly authorized to access. Users shall maintain all records containing University data in accordance with

University's Records Retention Policy and Records Management Guidelines.

- Users must not use or disclose Confidential University Data, or data that is otherwise confidential or restricted, without appropriate authorization. Examples of groups that can provide appropriate authorization include, but are not limited to Office of Admissions, Human Resource Services, Office of the VP for Institutional Relations and Legal Affairs, Information Security Office, and the university's Public Information Officer.
 - Users must ensure any individual with whom Confidential University Data is shared is authorized to receive the information.
 - Users may not share University Confidential Data with friends or family members.
 - Users may not share university business data that may be classified as Confidential Data, such as the status of negotiations, terms of contracts, and new research or products or relationships under development.
 - Users will comply with the university's agreements to protect vendor information such as software code, proprietary methodologies, and contract pricing.
- If User's office routinely receives requests for University Confidential Data, work with an appropriate group within the university to develop formal processes for documenting, reviewing, and responding to these requests.
- If Users receive a non-routine request for University Confidential Data from a third party outside of the university, check with an appropriate group within the university to make sure the release of the data is permitted.
- Users must report violations of university policies regarding use and/or disclosure of confidential or restricted information to the Information Security Office (security@utexas.edu, 512-475-9242).
- Unless technology prohibits, Users must store Confidential Information or other information essential to the mission of University on centrally managed storage services, rather than on local hard drives or portable devices.
- Confidential or essential University Data stored on a local hard drive or a portable device such as a laptop computer, tablet computer, or, smart phone, must be encrypted in accordance with University, System's, and any other applicable requirements.
- All Confidential University Data must be encrypted during transmission over a network.
- Users who store University Data using commercial cloud services must use [services provided or sanctioned by the University](#),

	rather than personally obtained cloud services. • Users must not try to circumvent login procedures on any University Information Resource or otherwise attempt to gain access where they are not allowed. Users may not deliberately scan or probe any University Information Resource without prior authorization. Such activities are not acceptable under any circumstances and can result in serious consequences. • All computers connecting to a University's network must run security software prescribed by the Information Security Officer as necessary to properly secure University Information Resources. • Devices determined by University to lack required security software or to otherwise pose a threat to University Information Resources may be immediately disconnected by the University from a University network without notice.
Email	• Emails sent or received by Users in the course of conducting University business are University Data that are subject to state records retention and security requirements. • Users must use University provided email accounts, rather than personal email accounts, for conducting University business. • The following email activities are prohibited when using a University provided email account: ◦ Sending an email under another individual's name or email address, except when authorized to do so by the owner of the email account for a work related purpose. ◦ Transmitting Confidential university data not encrypted prior to transmission. ◦ Accessing the content of another User's email account except: 1) as part of an authorized investigation; 2) as part of an approved monitoring process; or 3) for other purposes specifically associated with the User's official duties on behalf of University. ◦ Sending or forwarding any email that is suspected by the User to contain computer viruses. ◦ Any Incidental Use prohibited by this policy. ◦ Any use prohibited by applicable University or System policy.
Incidental Use of Information Resources	• Incidental Use of University Information Resources must not interfere with User's performance of official University business, result in direct costs to the University, expose the University to unnecessary risks, or violate applicable laws or other University or System policy.

- Users must understand that they have no expectation of privacy in any personal information stored by a User on a System Information Resource, including University email accounts.
- A User's incidental personal use of Information Resources does not extend to the User's family members or others regardless of where the Information Resource is physically located.
- Incidental Use to conduct or promote the User's outside employment, including self-employment, is prohibited.
- Users may not be paid, or otherwise profit, from the use of any university-provided information resource or from any output produced using it. Users may not promote any commercial activity using university information resources. Examples include, attempting to sell football tickets or used text books via the UT course management service or advertising a "Make Money Fast" scheme via a newsgroup. Such promotions are considered unsolicited commercial spam and may be illegal as well.
- Incidental Use for purposes of political lobbying or campaigning is prohibited.
- Storage of any email messages, voice messages, files, or documents created as Incidental Use by a User must be nominal.

Additional
Requirements
for Portable
and Remote
Computing

- All electronic devices including personal computers, smart phones or other devices used to access, create or store University Information Resources, including email, must be password protected in accordance with university requirements, and passwords must be changed whenever there is suspicion that the password has been compromised.
- University Data created or stored on a User's personal computers, smart phones or other devices, or in data bases that are not part of University's Information Resources are subject to Public Information Requests, subpoenas, court orders, litigation holds, discovery requests and other requirements applicable to University Information Resources
- University issued mobile computing devices must be encrypted.
- Any personally owned computing devices on which Confidential University Data is temporarily stored or created must be encrypted.
- University Data created and/or stored on personal computers, other devices and/or non-University databases must be transferred to University Information Resources as soon as feasible and deleted from the personal device.
- Unattended portable computers, smart phones and other computing devices must be physically secured.

	All remote access to networks owned or managed by University or System must be accomplished using a remote access method approved by the University or System, as applicable.
Password Management	- University issued or required passwords, including digital certificate passwords, Personal Identification Numbers (PIN), Digital Certificates, Security Tokens (i.e. Smartcard), or similar information or devices used for identification and authorization purposes shall be maintained securely and shall not be shared or disclosed to anyone or any unauthorized automated processes.. - Users must not give others access to University Information Resources unless they are authorized and authenticated for such access. Users may not extend access to university information resources to other parties or services without permission (e.g., proxy services, accounts for non-university personnel, etc). - Each User will be held responsible for all activities conducted using the User's password or other credentials.
User Acknowledgment I acknowledge that I have received and read the Information Resources Acceptable Use Policy. I understand and agree that my use of University Information Resources is conditioned upon my agreement to comply with the Policy and that my failure to comply with this Policy may result in disciplinary action up to and including termination of my employment. Signature: _____ Date_____ Print Name:_____	

Information Resources Acceptable Use & Security Policy Agreement

2.2 Any deviations in the U. T. Austin Acceptable Use Policy from the U. T. System Acceptable Use Policy model must be reviewed and approved by the U. T. System Office of General Counsel.

2.3 The Acceptable Use Policy must address the following User responsibilities and behaviors:

2.3.1.1 Ownership of U. T. Austin Information Resources and Data, including Data maintained or created on a User's personal devices;

2.3.1.2 Incidental use of Information Resources, including impact of placement of personal Data on U. T. Austin Information Resources;

2.3.1.3 User's expectations with regard to the privacy of information stored or created on U. T. Austin Information Resources;

2.3.1.4 User's responsibilities with respect to maintaining the security, integrity, and, as applicable, confidentiality of U. T. Austin Information Resources; and

2.3.1.5 Restrictions on the use of university-provided identifiers (e.g., institutional email addresses) and credentials for creating accounts on external sites or applications, and on the posting of organizational information or data on public websites or social media platforms.

2.4 U. T. Austin is responsible for ensuring that each User who is employed by the University or who provides services to or on behalf of the University acknowledges awareness of the existence of and the User's responsibility for complying with the U. T. Austin Acceptable Use Policy.

UT-IRUSP Standard 3: Information Security Program

3.1 Information Security Program Requirement. U. T. Austin must establish and maintain an Information Security Program that includes appropriate protections, based on risk, for all Information Resources including outsourced resources, owned, leased, or under the custodianship of any governing body or department, operating unit, or employee of the Institution.

3.2 Information Security Program. Each Information Security Program must include and document the following:

3.2.1 annual risk assessment;

3.2.2 current inventory of

3.2.2.1 institution-owned or managed computing devices, applications and vendor-managed services deployed throughout the institution, and

3.2.2.2 Mission-Critical applications and applications containing Confidential Data;

3.2.3 strategies to address identified risks to Mission-Critical Information Resources and Confidential Data;

3.2.4 annual action plan, training plan, and monitoring plan; and

3.2.5 metrics, reports, and timelines established by the U. T. System Office of Information Security.

3.3 Collection of Information Security Metrics. U. T. Austin must collect required metrics data in ways that are documented and verifiable.

3.4 Information Security Program Exceptions. The Owner of the Information Resource must work with the U. T. Austin Chief Information Security Officer must document and justify any exceptions to specific program requirements in accordance with requirements and processes defined in [UT-IRUSP Standard 23 – Security Control Exceptions](#).

3.5 Information Security Documentation Review. All U. T. Austin information security Policies, Standards, and Procedures must be reviewed and approved by the U. T. Austin Chief Information Security Officer, with UT System CISO involvement as applicable, at least once every three years, prior to initial publication of new documents, and whenever significant updates are made.

3.5.1 Information security documentation must be updated as needed upon: changes to applicable laws or regulations; updates to NIST 800-53 or other applicable compliance frameworks; significant changes to the organizational, technical, or legal environment; policy or risk landscape changes; security exception requests; or input from Subject Matter Experts or legal counsel.

3.6 DIR Compliance Assessment. U. T. Austin must conduct a biennial information security compliance assessment in accordance with Texas Government Code §2054.515 and Texas Administrative Code Chapter 202, and submit required documentation to the Texas Department of Information Resources on the schedule required by applicable law.

3.7 DIR Information Security Plan. In accordance with Texas Government Code Section 2054.133, the U. T. Austin Chief Information Security Officer must prepare and submit a comprehensive Information Security Plan to the Texas Department of Information Resources by June 1st of every even-numbered year. The plan must include, at minimum: (a) a Maturity Assessment against the Texas Cybersecurity Framework (TCF); (b) a Vulnerability Report Questionnaire as required by TGC Section 2054.077; and (c) an Executive Written Acknowledgment of Risk signed by the Chief

Administrative Officer or designee. The plan must be reviewed and updated annually.

UT-IRUSP Standard 4: Access Management

Proper management and use of computer accounts are basic requirements for protecting the university's Information Resources. All offices that create access accounts for applications, networks, or systems are required to manage the accounts in accordance with the university's access management processes. Access to an Information Resource may not be granted by another User without the permission of the Owner or the Owner's delegated custodian of that Information Resource. All accounts are to be created and managed using the following required account management practices:

4.1 Access Management Requirements

4.1.1 All accounts that access non-public university Information Resources must follow an account creation process. This process shall document who is associated with the account, the purpose for which the account was created, and who approved the creation of the account at the earliest possible point of contact between the account holder and the university. All accounts wishing to access the university's non-public Information Resources must have the approval of the Owner of those resources. These measures also apply to accounts created by/for use of outside vendors or contractors.

4.1.2 Each account having special privileges must adhere to the university's password requirements.

4.1.3 All accounts must be able to be associated with an identifiable individual or group of individuals that are authorized to use that account (for example, the UT-EID) and integrated with University-wide authentication systems (for example, Enterprise Authentication). Any hosted or 3rd party managed applications using local or standalone accounts must first have an approved [Exception Request](#) on file with the Information Security Office.

4.1.4 Accounts for individuals who are no longer actively affiliated with the university, are on extended leave (more than 120 days), or accounts that have not been accessed in more than 120 days must be disabled.

4.1.5 Account passwords shall be expired based on Risk.

4.1.6 Accounts of individuals who have had their status, roles, or affiliations with university change must be updated to reflect their current status.

4.1.7 Accounts must be reviewed at least annually to ensure their current state is correct.

4.1.8 Password aging and expiration dates must be enabled on all accounts created for outside vendors, external contractors, or those with contractually limited access to the university's information resources.

4.2 Remote and Wireless Access. Remote and wireless Access to U. T. Austin Network Infrastructure must be managed to preserve the Integrity, availability, and confidentiality of U. T. Austin Information. Remote and Wireless Access Policies and Procedures must:

4.2.1 establish and communicate to Users the roles and conditions under which Remote or wireless Access to Information Resources containing Confidential Data is permitted;

4.2.2 require the use of secure and encrypted connections when accessing Information Resources containing Confidential Data across the Internet, or across unsecured or public networks (e.g., use of VPN for access, SFTP for transfers, encrypted wireless); and

4.2.3 require monitoring for identifying and disabling of unauthorized (i.e., rogue) wireless access points.

4.3 Access to U. T. Austin Networks. Through appropriate use of administrative, physical, and technical controls, the U. T. Austin office or offices charged with maintaining the Network Infrastructure are required to establish processes for approval of all network hardware connected to the U. T. Austin network and the methods and requirements for attachment, including any Non-U. T. Austin Owned Computer Systems or Devices, to ensure that such access does not compromise the operations and reliability of the network, or compromise the Integrity or use of Information contained within the network.

4.4 Data Access Control Requirement. All Owners and Custodians must control and monitor access to Data within their scope of responsibility based on Data sensitivity and Risk, and through use of appropriate administrative, physical, and technical safeguards including the following:

4.4.1 Owners must limit access to records containing Confidential Data to those employees who need access for the performance of the employees' job responsibilities. An employee may not access Confidential Data if it is not necessary and relevant to the employee's job function.

4.4.2 Owners and Custodians must monitor access to records containing Confidential Data by the use of appropriate measures as determined by applicable Policies, Standards, Procedures, and regulatory requirements.

4.4.3 Owners and Custodians must establish log capture and review processes based on Risk and applicable Policies, Standards, Procedures, and regulatory requirements. Such processes must define:

4.4.3.1 the Data elements to be captured in logs;

4.4.3.2 the time interval for custodial review of the logs; and

4.4.3.3 the appropriate retention period for logs.

4.4.4 Employees may not disclose Confidential Data to unauthorized persons or Institutions except:

4.4.4.1 as required or permitted by law, and, if required, with the consent of the Data Owner;

4.4.4.2 where the third-party is the agent or contractor for the U. T. Austin and the safeguards described in Standard 4.5 are in place to prevent unauthorized distribution; or

4.4.4.3 as approved by the U. T. Austin Office of Legal Affairs or the U. T. System Office of General Counsel.

4.5 Access for Third-Parties. If U. T. Austin intends to provide University Data to a third-party acting as an agent of or otherwise on behalf of U. T. Austin (example: an application service provider) a written agreement with the third-party is required.

4.5.1 Such third-party agreements must specify:

4.5.1.1 the Data authorized to be accessed;

4.5.1.2 the circumstances under and purposes for which the Data may be used; and

4.5.1.3 that all Data must be returned to U. T. Austin, or destroyed, in a manner specified by U. T. Austin upon end of the third-party engagement.

4.5.2 If U. T. Austin determines that its provision of Data to a third-party will result in significant Risk to the confidentiality, Integrity, or availability of such Data, the agreement must specify terms and conditions, including appropriate administrative, physical, and technical safeguards for protecting the Data.

4.6 Multi-factor Authentication Requirements.

Multi-factor Authentication is required in the following situations:

4.6.1 For all UTEID-authenticated services or other Internet-accessible logins provided to active faculty, staff or students regardless of their location (on or off campus).

4.6.1.1 Additional technical limitations and requirements will be placed on central IT staff responsible for critical IT infrastructure to ensure reasonable controls are in place to manage associated risks.

4.6.2 When an employee or other individual providing services on behalf of the University (such as a student employee, contractor, or volunteer) logs on to a University network using an enterprise Remote Access protocol or gateway such as VPN, Remote Desktop, Terminal Server, Connect, Citrix, or similar services;

4.6.3 When an individual described in (a) who is working from a Remote Location uses an online function such as a web page to modify or view protected health information, employee banking, tax, or financial Information; or

4.6.4 When a Computing Device administrator or other individual working from a Remote Location uses administrator credentials to access another Computing Device that contains or has access to Confidential University Data.

4.6.5 When an employee or other individual providing services on behalf of the University who is working from a Remote Location accesses a web-based interface to University email.

4.6.6 Additional implementation details are available in the U. T. Austin Information Security Office's [Approved Multi-Factor Authentication Methods](#).

UT-IRUSP Standard 5: Administrative/Special Access Accounts

Users must be made aware of the privileges granted to their administrative accounts, especially those that impact access to information resources or that allow them to circumvent controls in order to administer the information resource. Abuse of such privileges will not be tolerated. Anyone using accounts with elevated access privileges of this type must adhere to the following access requirements.

5.1 All IT System Custodians will be granted administrative access to the university-owned IT devices (e.g., laptops, desktops, tablets, servers) deployed in their respective college, school, or unit. Individuals who use accounts with special privileges (for example, System Administrators) must only use these accounts for their intended administrative purposes.

5.1.1 All administrative accounts must follow this naming convention: <DEPTCODE>-<eid>-<optional-suffix>. For example: *ITSY-jonesuser-sa* or *ITSY-phillips3d*.

5.1.2 All administrative accounts credentials will be required to be rotated on a regular basis (e.g., at least annually) and will be configured so as not to be cached on local devices. All Austin Active Directory department user accounts will be placed in the Protected Users Security group to ensure additional protections against credential theft attacks and to prevent plaintext or offline credentials from being cached on endpoints.

5.2 All access via administrative accounts must be logged to system management services in place centrally to ensure proper accountability and transparency. These logs should be retained, according to U. T. Austin retention schedules, and routinely audited.

5.3 Individuals who use administrative accounts may not [perform investigations](#) relating to the potential misuse of information resources by an individual user except under the direction of the Information Security Office or the Office of Legal Affairs.

5.4 All colleges, schools, and units of the university must maintain an updated list of IT Support Staff in the university [Department System](#).

5.5 All U. T. Austin employees must complete a [Background Check for Staff/Faculty](#) and must acknowledge their responsibilities by

annually completing the [Acceptable Use Acknowledgement form](#).

5.6 The password for a shared administrative account must change when any individual knowing the password leaves the department or university or changes role; or upon a change in the vendor personnel assigned to university contracts having password access.

5.7 For all systems serving out Information Resources there must be a password escrow procedure in place to enable someone other than the administrator to gain access to the system in an emergency situation (e.g., via [Stache](#)).

5.8 When access to a university-owned IT device's administrative account is required by someone other than an IT Support Staff member, the following exception criteria must apply:

5.8.1 Individuals must have a valid need for an administrative account and annually complete the [Acceptable Use Acknowledgement form](#);

5.8.2 Individuals must only use an administrative account for special administrative functions related to the valid need noted above and default to a lower privileged user account for other day-to-day use;

5.8.3 Individuals must review training to inform them how they can limit use of their administrative access and still accomplish their primary day-to-day functions (example: [How not to Login as Administrator \(and still get your job done\)](#));

5.8.4 IT System Custodians are required to periodically review the use of administrative account exceptions.

5.8.4.1 IT System Custodians will remove any administrative accounts that go unused or are no longer required; and

5.8.4.2 IT System Custodians are required to raise inappropriate use to management (e.g., staying logged in with the administrative account longer than needed).

UT-IRUSP Standard 6: Backup and Disaster Recovery

6.1 Backup Plan Requirement. All U. T. Austin Data, including Data associated with research, must be backed up in accordance with Risk management decisions implemented by the Data Owner. The university's Office of Internal Audit periodically reviews backup plans for campus units. Each Backup plan must incorporate Procedures for:

6.1.1 recovering Data and applications in case of events such as natural disasters, system disk drive failures, espionage, Data entry errors, human error, or system operations errors;

6.1.2 assigning operational responsibility for backing up of all Servers;

6.1.3 scheduling Data Backups and establishing requirements for off-site storage;

6.1.4 securing on-site/off-site storage and Media in transit, as necessary; and

6.1.5 testing Backup and recovery Procedures.

6.2 Disaster Recovery Plan. Owners of Mission Critical Information Resources and of Information Resources containing Confidential Data must adopt a disaster recovery plan commensurate with the Risk and value of the Information Resource and a completed [Business Impact Analysis](#). The university's Office of Internal Audit periodically reviews disaster recovery plans for campus units. The disaster recovery plan must incorporate Procedures for:

6.2.1 recovering Data and applications in the case of events that deny access to Information Resources for an extended period (e.g., natural disasters, terrorism);

6.2.2 assigning operational responsibility for recovery tasks and communicating step-by-step implementation instructions;

6.2.3 testing the disaster recovery plan and Procedures at least once annually (example: tabletop or scenario testing, leveraging major scheduled upgrades, activating actual service outages in a controlled scenario); and

6.2.4 making the disaster recovery plan available to the U. T. Austin Chief Information Security Officer and other stakeholders via the [UT Ready](#) disaster recovery planning service.

UT-IRUSP Standard 7: Change Management

The university's Information Resources infrastructure is constantly changing and evolving to support the mission of the university. Computer networks, systems, and applications require planned outages for upgrades, maintenance, and fine-tuning. The [Change Management Guidelines](#) provide expanded detail for the following change management procedures that are required, as warranted by

the [Data Classification Standard](#) and commensurate with the risk and value of the system and/or data:

7.1 All changes to environmental controls affecting computing facility machine rooms (for example, air-conditioning, water, heat, plumbing, electricity, and alarms) must be logged and reported to the appropriate college, school, or unit managing the systems in that facility.

7.2 Colleges, schools, or units responsible for information resources will ensure that the change management procedures and processes they have approved are being performed.

7.3 Colleges, schools, or units may object to a scheduled or unscheduled change for reasons including, but not limited to, inadequate planning, inadequate back out contingencies, inopportune timing in terms of impact on service to users or in relation to key business process such as year-end accounting, or lack of resources to address potential problems that may be caused by the change. The responsible party will review all objections. A security exception request may be submitted to the Information Security Office if there are objections to a planned change that is triggered by security requirements.

7.4 Whenever possible, customers will be notified of changes following the steps contained in the change management procedures.

7.5 A responsible college, school, or unit, consistent with change management procedures, maintains a [change management log](#) for all significant changes including emergency changes. Change management log entries must contain at least the following information:

7.5.1 Date of submission and date of change;

7.5.2 Owner and custodian contact information; and

7.5.3 The nature of the change.

7.6 All Custodians must implement and adhere to approved U. T. Austin [Change Management guidelines](#) to ensure secure, reliable, and stable operations.

UT-IRUSP Standard 8: Malware Prevention

8.1 Protecting U. T. Austin Infrastructure. U. T. Austin's Network Infrastructure and other Information Resources must be continuously protected from threats posed by Malware.

8.2 All computing devices owned, leased, or under the control of U. T. Austin must, to the extent technology permits, implement and keep up to date technology innovations for malware detection and response and adhere to any other protective measures as required by applicable Policies and Procedures.

8.2.1 Anti-malware software must not be disabled or removed from any computing device, must provide real-time scanning capabilities, and must include scanning at all email ingress and egress points.

8.3 Any personally owned Computing Device that is approved to contain Confidential University Data as noted under [Section 11.3.3](#) must be verifiably configured (e.g., Nessus Agents or end point management) to comply with required University security controls while holding such Data or connecting to any University network.

8.4 Any system identified as a security risk due to a lack of virus protection may be disconnected from the network or the respective network account may be disabled until adequate protection is in place.

8.5 U. T. Austin makes various malware prevention tools available at no added cost: <https://security.utexas.edu/education-outreach/anti-virus>.

8.6 Exceptions should be acknowledged by completing a [Security Exception Report](#).

UT-IRUSP Standard 9: Data Classification.

9.1 All data owners, data stewards, or designated custodians, shall be responsible for classifying Data stored, processed, or transmitted by systems under their purview based on data sensitivity and risk so that the appropriate security controls can be applied.

9.2 The [Data Classification Standard](#) shall be used to classify Data.

9.2.1 Systems storing university Data will be assessed annually in a campus-wide risk assessment where each system is classified based on the Data it is associated with.

9.3 A data classification of Confidential (historically referred to as Category-I) shall be based on compliance with applicable Federal or

State law, a contract, or on the demonstrated need to (a) document the integrity of that Data (that is, the data has not been altered by either intent or accident), (b) restrict and document individuals with access to that Data, and (c) ensure appropriate backup and retention of that Data.

9.4 Classification Responsibility. Owners of Information Resources within U. T. Austin must classify Data based on the U. T. Austin Data Classification Standard and shall ensure the classification is properly maintained in the event the data classification changes.

9.5 The U. T. Austin Data Classification Standard consists of three mutually exclusive Data classifications based on fit within a spectrum indicating the degree to which access to the Data must be restricted and Data Integrity and availability must be preserved. The three classifications are as follows:

Data Classification and Description	Examples	Comments
Confidential Information / Data Information (or Data) is classified as Confidential if it must be protected from unauthorized disclosure or public release based on State or Federal law or regulation, and by applicable legal agreement to the extent permitted by law. <i>Historically, this type of Data has been referred to as Category-I Data.</i>	Patient billing Information and Protected Health Information subject to HIPAA or applicable state law. Student education records subject to FERPA. A credit card number associated with an individual's name. A social security number. Medical Research Data that contains protected health information. Certain student loan Information subject to the Gramm Leach Bliley Act.	Information (Data) cannot simply be declared to be "Confidential." This classification is reserved for Information that is protected from public release based on State or Federal law, or a legally binding order or agreement. Likewise, Data cannot be declared to be "Confidential" under all circumstances. Context is an essential element. (In relation to the Federal Standards for Security Categorization of Federal Information and Information Systems , FIPS 199, this category equates to HIGH IMPACT for a Confidentiality, Integrity, and Availability breach)

Data Classification and Description

Controlled Information / Data

The Controlled classification applies to Information/Data that is not generally created for or made available for public consumption, but may be subject to release to the public through request via the Texas Public Information Act or similar State or Federal law.

Historically, this type of Data has been referred to as Category-II Data.

Examples

Operational records, operational statistics, employee salaries, budgets, expenditures. Internal communications that do not contain Confidential Information. Research Data that has not yet been published, but which does not contain Confidential Information protected by law or applicable legal agreement.

Comments

This classification likely encompasses the greatest volume of Data within the University. (In terms of FIPS 199, this category equates to MODERATE IMPACT for a Confidentiality, Integrity, and Availability breach)

Published Information / Data

Published Information/Data includes all Data made available to the public through posting to public websites, distribution through Email, Social Media, print publications, or other Media.

Historically, this type of Data has been referred to as Category-III Data.

Statistical reports, Fast Facts, Published Research, unrestricted directory Information, educational content available to the public at no cost.

Information can migrate from one classification to another based on Information life-cycle. Unpublished Research may fit the criteria of "Controlled Information" until published upon which it would become Published Information. (In terms of FIPS 199, this category equates to LOW IMPACT for a Confidentiality, Integrity, and Availability breach.)

Data Classification

UT-IRUSP Standard 10: Risk Management

10.1 The U. T. Austin Chief Information Security Officer must maintain an accurate inventory of Information Resources and associated Owners.

10.1.1 All assets (systems, cloud-hosted systems, applications, vendor products) must be routinely accounted for by their Data Owners or local IT support staff in [ISORA](#), the university risk management service.

10.2 Information Resources Owners. For Information Resources under the Owners' authority, Owners must, in consultation with the U. T. Austin Chief Information Security Officer:

10.2.1 define, approve, and document acceptable Risk levels and Risk mitigation strategies; and

10.2.2 conduct and document Risk assessments to determine Risk and the Inherent Impact that could result from their unauthorized access, use, disclosure, disruption, modification, or destruction. Timing of assessments shall be annually for all Information Resources and Information Resources.

10.3 Information Resources Custodians. Custodians of Mission Critical Information Resources must implement approved Risk mitigation strategies and adhere to Information Security Policies and Procedures to manage Risk levels for Information Resources under their care.

10.4 The U. T. Austin Chief Information Security Officer must ensure that annual Information Security Risk assessments are performed and documented by each Owner of Information Resources and that risk assessment results are documented in a written report that ranks identified risks as High, Moderate, or Low, consistent with UT System guidance.

10.5 Sponsored Projects. Principal Investigators must perform security assessments, in collaboration with the Office of Sponsored Projects and the U. T. Austin Chief Information Security Officer, of the implementation of required security controls (i.e. control objectives, controls, Policies, processes, and Procedures for Information security) for sponsored projects under their authority. Security assessments for sponsored projects must be performed annually based on Risk.

10.6 Risk Assessment of Third-party Service Providers. A risk assessment of a third-party service provider is required in the

following situations:

10.6.1 when purchasing services that result in exchange of Confidential University Data or hosting of Confidential University Information Resources with a Vendor or other organization; or

10.6.2 when purchasing systems or software, whether it is to be hosted on premises or at a Vendor facility, if Confidential University Data will be stored within or processed by the system or software.

10.7 Information Security Risk Assessments that are to be aggregated for system-wide reporting to the U. T. System Executive Compliance Committee and/or the U. T. System Board of Regents shall be conducted using a risk management framework and process defined by U. T. System Office of Information Security and shall be coordinated at the Institutional level by the U. T. Austin Chief Information Security Officer.

10.8 Risk Acceptance. Decisions relating to acceptance of Risk must be documented and are to be made by:

10.8.1 the Information Resource Owner, in consultation with the U. T. Austin Chief Information Security Officer or designee, for resources having a residual Risk of Low or Moderate.

10.8.2 the Chief Administrative Officer, or designee, considering recommendations of the Owner and the U. T. Austin Chief Information Security Officer for resources having a residual Risk of High.

UT-IRUSP Standard 11: Safeguarding Data

11.1 U. T. Austin's Policies, Standards, and/or Procedures must describe and require steps to protect University Data using appropriate administrative, physical, and technical controls in accordance with the U. T. Austin Information Security Program and Data Classification Standard, and UTS165 and its associated Standards.

11.1.1 The [Minimum Security Standards for Systems](#) describe and require appropriate steps to protect Confidential Data stored, processed, or transmitted on the university's computing devices.

11.1.2 The [Minimum Security Standards for Application Development and Administration](#) describe and require appropriate steps to protect Confidential Data stored, processed, or transmitted on the university's applications.

11.2 Third-Party Service Providers Storing University Data. University Data must not be stored on personally procured third-party (e.g. Cloud) storage services.

11.2.2 All third-party services processing Confidential university data must have a valid contract in place that has been signed by the [Business Contracts Office](#).

11.2.3 All third-party services processing Confidential university data must have a completed vendor security assessment in [ISORA](#), which is renewed annually.

11.3 Password and Encryption Protection for Computing Devices and Data.

11.3.1 Desktop Computers.

11.3.1.1 All High Risk Desktop Computers owned, leased, or controlled by the University must be Password protected and encrypted, regardless of data classification, using methods approved by the U. T. Austin Chief Information Security Officer.

11.3.1.2 All desktop computers purchased after September 1, 2013 must be Password protected and encrypted, regardless of data classification, using methods approved by the U. T. Austin Chief Information Security Officer before their deployment.

11.3.2 Laptop Computers and Other Mobile Devices.

11.3.2.1 All laptop computers and other mobile devices, including but not limited to mobile and smart phones, and tablet computers, that are owned, leased, or controlled by the University, must be encrypted, regardless of data classification, using methods approved by the U. T. Austin Chief Information Security Officer.

11.3.2.2 USB thumb drives and similar removable storage devices owned, leased, or controlled by the University must be encrypted, using methods approved by the U. T. Austin Chief Information Security Officer, before storage of any Confidential University Data on the device.

11.3.3 Personally Owned Devices. Specific permission must be obtained from the department head with an exception request approved by the Information Security Office, before a user may store Confidential University Data on any personally owned computers, mobile devices, USB thumb drives, or similar devices. Such permission should be granted only upon demonstration of a business

need and an assessment of the risk introduced by the possibility of unauthorized access or loss of the data. All personally owned computers, mobile devices, USB thumb drives, or similar devices must be Password protected and encrypted using methods approved by the U. T. Austin Chief Information Security Officer if they contain any of the following types of University Data:

11.3.3.1 Information made confidential by Federal or State law, regulation, or other legally binding order or agreement;

11.3.3.2 Federal, State, University, or privately sponsored Research that requires confidentiality or is deemed sensitive by the funding entity; or

11.3.3.3 any other Information that has been deemed by U. T. Austin Institution as essential to the mission or operations of U. T. Austin to the extent that its Integrity and security should be maintained at all times.

11.3.4 [Approved Encryption Methods](#) are published and maintained by the U. T. Austin Information Security Office.

11.3.5 Exceptions must be filed with the [Information Security Office](#) in the event of hardware compatibility conflicts, technology limitations for certain types of devices, etc. All exceptions must note why alternative solutions are not possible (newly purchased hardware should be selected to adhere to U. T. Austin standards prior to purchase) and identify the compensating controls that will be implemented to offset the risk created by the lack of encryption. A single exception may be filed for a number of devices as long as the devices can be uniquely identified (e.g., UT Tag, Serial, MAC address).

11.4 Assured Access to Encrypted Data.

11.4.1 Data and device owners are responsible for ensuring encrypted data will be accessible in the event decryption keys or related credentials become lost or forgotten and no other copy of the data is available. Only [escrow methods approved by the U.T. Austin Chief Information Security Officer are permissible](#).

11.5 Protecting Data in Transit. Data Owners shall implement appropriate administrative, physical, and technical safeguards necessary to adequately protect the security of Data during transport and electronic transmissions. Each of the following shall be addressed:

11.5.1 identification and transmission of the least amount of Confidential Data required to achieve the intended business objective;

11.5.2 encryption of all Confidential Data transmitted over the Internet or the U. T. Austin network;

11.5.3 encryption of all Confidential Data transmitted between Institutions and Shared Data Centers; and

11.5.4 deletion of transmitted and received Confidential Data upon completion of the intended business objective.

11.6 Protecting Common Use Information Resources.

11.6.1 The ISO for Common Use Infrastructures is responsible for implementation of an Information Security Program for Common Use Infrastructures, and for documenting associated roles and responsibilities.

11.6.2 For services provided via Common Use Infrastructures, Memorandum of Understanding (MOU) documents between U. T. System and host Institutions, and between U. T. System and participant Institutions must identify roles and responsibilities for provision of Information security controls.

11.7 Discarding Electronic Media. Institutions must discard Electronic Devices and Media containing University Data:

11.7.1 in a manner that adequately protects the confidentiality of the Data and renders it unrecoverable, such as overwriting or modifying the Electronic Media to make it unreadable or indecipherable or otherwise physically destroying the Electronic Media; and

11.7.2 in accordance with the applicable institutional records retention schedule; and

11.7.3 for assets that have stored Confidential Data, in a manner that sanitizes the asset using methods approved by the U. T. Austin Chief Information Security Officer prior to transfer out of University control or reuse, and maintains a record of the sanitization method and affected assets in accordance with applicable records retention requirements.

11.8 As required by Section 2054.517 of the Texas Government Code, the university shall adopt and implement a policy for Internet website and mobile application security procedures that complies with this

Standard and aligns with the [Minimum Security Standards for Application Development and Administration](#). The Chief Information Security Officer is responsible for developing and implementing the policy and procedures in conjunction with the Office of Legal Affairs, Privacy Officer, and other officials responsible for compliance with privacy laws (including HIPAA and FERPA) and data security laws.

The policy and procedures should consider business processes such as contracting, acceptance testing, and system deployment, etc.

11.8.1 Before deploying an Internet website or mobile application that processes Confidential university information, the developer of the website or application must submit to the Information Security Office the information required [Minimum Security Standards for Application Development and Administration](#) to protect the privacy of individuals by preserving the confidentiality of information processed by the website or application.

11.8.2 Before deploying an Internet website or mobile application that processes Confidential university information the website or application must be subjected to a vulnerability and penetration test conducted internally or by an independent third party. Review and acceptance of the findings shall comply with IRUSP Standard 10.8.

11.8.3 The university shall submit to the Texas Department of Information Resources the policies adopted as required by Section 2054.517 of the Texas Government Code. The U.T. Austin Chief Information Security Officer is responsible for ultimate content and implementation of the policy.

11.9 University employees and authorized users must adhere to applicable data classification requirements when using artificial intelligence tools, platforms, or services. Confidential Data must not be submitted to an artificial intelligence tool or service without prior approval from the U. T. Austin Chief Information Security Officer.

11.9.1 The U. T. Austin Chief Information Security Officer must maintain and publish a list of approved artificial intelligence tools and the data classifications authorized for use with each. Controlled or Confidential Data must only be used with tools on this approved list that meet all of the following requirements:

11.9.1.1 the tool is managed by the university;

11.9.1.2 the tool is covered by a contract that prohibits the use of university data for training AI models; and

11.9.1.3 web search functionality is disabled.

11.9.2 University employees and authorized users must not accept click-through or end-user license agreements for artificial intelligence tools on behalf of the university without delegated signature authority.

11.9.3 As required by Texas Government Code §2054.707, the university must disclose to individuals when they are interacting with a public-facing artificial intelligence system prior to or at the start of that interaction, unless a reasonable person would know they are interacting with an artificial intelligence system. The U. T. Austin Chief Information Security Officer must develop and maintain procedures for implementing this requirement.

11.9.4 The university must not deploy or procure a Heightened Scrutiny Artificial Intelligence System, as defined in Texas Government Code §2054.003, without prior review and approval by the U. T. Austin Chief Information Security Officer. Approved Heightened Scrutiny Artificial Intelligence Systems must:

11.9.4.1 incorporate meaningful human review of all consequential outputs;

11.9.4.2 be documented in a registry maintained by the U. T. Austin Chief Information Security Officer; and

11.9.4.3 be reviewed at least annually to assess ongoing risk and continued compliance with this Policy.

UT-IRUSP Standard 12: Security Incident Management

12.1 Reporting Requirements. Security Incidents will be reported as required by State and Federal law and University Policy, including the U. T. System Information Security Incident Reporting Requirements.

12.2 Incident Management Procedures.

12.2.1 Incidents involving computer security will be managed by the Information Security Office and will be reported as required by Federal or State law or regulation.

12.2.2 The Information Security Office is required to establish and follow Incident Management Procedures to ensure that each incident is reported, documented, and resolved in a manner that restores

operation quickly and, if required, maintains evidence for further disciplinary, legal, or law enforcement actions.

12.2.3 All faculty members, staff, and/or students shall report promptly any unauthorized or inappropriate disclosure of Confidential Digital Data, including social security numbers, to: the U. T. Austin Chief Information Security Officer (via security@utexas.edu or 512-475-9242); their supervisors; and/or the university's compliance hotline (via helpline@compliance.utexas.edu or 1-877-888-0002).

12.2.4 The U. T. Austin Chief Information Security Officer shall report to the UT System CISO incidents involving computer security that compromise the security, confidentiality, or integrity of Confidential Digital Data or personal identifying information it maintains.

12.2.5 The university shall disclose, in accordance with applicable Federal or State law, incidents involving computer security that compromise the security, confidentiality, and/or integrity of personal identifying information it maintains to Data Owners and any resident of Texas whose personal identifying information was, or is reasonably believed to have been, acquired without authorization.

12.2.6 Disclosure shall be made as quickly as possible upon the discovery or receipt of notification of the incident taking into consideration (a) the time necessary to determine the scope of the incident and restore the reasonable integrity of operations, or (b) any request of a law enforcement agency that determines that the notification will impede a criminal investigation. The notification shall be made as soon as the law enforcement agency determines that it will not compromise the investigation.

12.2.7 The Information Security Office's Incident Management Procedures must incorporate the following:

12.2.7.1 The university will establish a Computer Incident Response Team (CIRT) that, in the event of a significant computer security incident, will initiate and follow the Incident Management Procedures. The members of this team will have defined roles and responsibilities that, based on the severity of the incident, may take priority over normal duties.

12.2.7.2 The U. T. Austin Chief Information Security Officer will report the incident to the appropriate university, State, and Federal agencies and departments as required by governing laws, rules, and procedures.

12.2.7.3 The U. T. Austin Chief Information Security Officer, working with the selected Computer Incident Response Team members, will determine if a widespread university communication is required, the content of any such communication, and the method of distribution.

12.2.7.4 The U. T. Austin Chief Information Security Officer will be responsible for maintaining a chain of evidence on incidents it investigates, or participates in investigating, in case the incident needs to be referred to law enforcement or for other legal proceedings.

12.2.7.5 The U. T. Austin Chief Information Security Officer is responsible for determining the physical and electronic evidence to be gathered as part of the incident investigation, except in cases involving appropriate law enforcement personnel, where the University Police Department or other law enforcement agencies will make these determinations.

12.2.7.6 Technical staff members from the Computer Incident Response Team (CIRT), led by the U. T. Austin Chief Information Security Officer, are responsible for ensuring that any damage from a security incident is repaired or mitigated and that the vulnerability is eliminated or minimized.

12.2.7.7 The U. T. Austin Chief Information Security Officer is responsible for communicating new issues or vulnerabilities to vendors as needed, and for working with the vendors to eliminate or mitigate the vulnerabilities.

12.2.7.8 The U. T. Austin Chief Information Security Officer is responsible for initiating, completing, and documenting the incident investigation with assistance from the Computer Incident Response Team. The University Police Department serves as liaison with law enforcement organizations.

12.3 Employee Reporting. All employees must promptly report unauthorized or inappropriate disclosure of Confidential Data, in digital, paper, or any other format, to: the U. T. Austin Chief Information Security Officer (via security@utexas.edu or 512-475-9242); their supervisors; and/or the university's compliance hotline (via helpline@compliance.utexas.edu or 1-877-888-0002).

12.4 Reporting to the Institutional Information Security Officer. Information Resources Owners, Custodians, and any supervisor or manager who becomes aware of a Security Incident is to report the incident to: the U. T. Austin Chief Information Security Officer (via

security@utexas.edu or 512-475-9242); or the university's compliance hotline (via helpline@compliance.utexas.edu or 1-877-888-0002).

12.5 Reporting Requirements to U. T. System. The U. T. Austin Chief Information Security Officer must report significant Security Incidents to the U. T. System CISO. Security Incidents resulting in unauthorized disclosure of University Data must be reported immediately. The U. T. Austin Chief Information Security Officer must report Security Incidents to the U. T. System CISO prior to reporting to non-U. T. System agencies or organizations except as required by State or Federal law.

12.6 Monitoring Techniques and Procedures. Custodians must implement monitoring controls and Procedures for detecting, reporting, and investigating incidents.

UT-IRUSP Standard 13: Use and Protection of Social Security Numbers

The university recognizes the special risks associated with the collections, use, and disclosure of social security numbers. Accordingly, the requirements of this section to apply to all social security numbers contained in any medium, including paper records that are collected, maintained, used, or disclosed by the university.

13.1 The University shall discontinue the use of all or part of the social security number as an individual's primary identification number unless required or permitted by law. The social security number may be stored as a confidential attribute associated with an individual only if use of the social security number is essential for the performance of a mission related duty.

13.1.1 If the maintenance and use of social security numbers is permitted, but not required by applicable law, the university shall permit the maintenance and use of social security numbers only as reasonably necessary for the proper administration or accomplishment of their respective business, governmental, educational and medical purposes, and only if the university determines that the benefit outweighs the potential Risk created by the particular maintenance or use of the social security number. Potential purposes may include:

13.1.1.1 use as a means of identifying an individual for whom a unique identification number is not known;

13.1.1.2 use for internal verification or administrative purposes where it is not feasible to use some other identifier; and

13.1.1.3 use for verification or administrative purposes by a third-party or its agent in conducting business on behalf of U. T. Austin, where the third-party or agent has contracted to comply with the safeguards described in [UT-IRUSP Standard 11 - Safeguarding Data](#).

13.1.2 Except in those instances in which U. T. Austin is legally required to collect a social security number, an individual shall not be required to disclose all or part of his or her social security number, nor shall the individual be denied access to the services at issue if the individual refuses to disclose his or her social security number. An individual, however, may volunteer his or her social security number. A request by U. T. Austin that an individual provide his or her social security number for verification of the individual's identity where the social security number has already been disclosed does not constitute a disclosure for purposes of this Standard. The links include examples of [Federal laws](#) and [State laws](#) that require the collection or use of social security numbers. Questions about whether a particular use is required by law should be directed to the U. T. Austin Chief Information Security Officer, who will consult with the Office of Legal Affairs with respect to the interpretation of law.

13.1.3 U. T. Austin may, but is not required to, designate only selected offices and positions as authorized to request that an individual disclose his or her social security number.

13.1.4 U. T. Austin shall assign a unique identifier (e.g., a UT EID) for each applicant, student, employee, insured dependent, research subject, patient, alumnus, donor, contractor, and other individuals, as applicable, at the earliest possible point of contact between the individual and the university for use in lieu of a social security number.

13.1.5 The unique identifier shall be used in all electronic and paper Information Systems to identify, track, and serve these individuals. The unique identifier shall:

13.1.5.1 be a component of a system that provides a mechanism for the public identification of individuals;

13.1.5.2 be permanent and unique within the university as applicable, and remain the property of, and subject to the rules of, U. T. Austin; and

13.1.5.3 not be derived from the social security number of the individual; or, in the alternative, if the unique identifier is derived from the social security number, it must be computationally infeasible to ascertain the social security number from the corresponding unique identifier.

13.1.6 All services and Information Systems shall rely on the identification services provided by the unique identifier system.

13.2 U. T. Austin shall provide notice to individuals when they collect social security numbers.

13.2.1 Each time the university requests that an individual initially disclose his or her social security number, it shall provide the notice required by [Section 7 of the Federal Privacy Act of 1974 \(5 U.S.C. § 552a\)](#), which requires that the individual be informed whether the disclosure is mandatory or voluntary, by what statutory or other authority the number is solicited, and what uses will be made of it. A subsequent request for production of a social security number for verification purposes does not require the provision of another notice.

13.2.1.1 The notice shall use the applicable text from [Preapproved Sample Disclosures](#) or such other text as may be approved by the U. T. Austin Office of Legal Affairs.

13.2.1.2 Notices shall be in writing if possible. If a verbal notice is required, such notice shall be promptly documented.

13.2.2 In addition to the notice required by the Federal Privacy Act, when the social security number is collected by means of a form completed and filed by the individual, whether the form is printed or electronic, the notice as required by [Section 559.003 of the Texas Government Code](#) must also be provided. That section requires that the agency state on the paper form or prominently post on the Internet site in connection with the form that: with few exceptions, the individual is entitled on request to be informed about the Information that is collected about the individual; under [Sections 552.021 and 552.023 of the Government Code](#), the individual is entitled to receive and review the Information; and under [Section 559.004 of the Government Code](#), the individual is entitled to have the incorrect Information about the individual corrected.

13.2.3 Employees may not seek out or use social security numbers relating to others for their own interest or advantage.

13.2.4 U. T. Austin shall eliminate the public display of social security numbers.

13.2.4.1 Grades may not be publicly posted or displayed in a manner in which all or any portion of either the social security number or the unique identifier identifies the individual associated with the Information.

13.2.4.2 Social security numbers shall not be displayed on documents that are accessible to individuals who do not have a business reason to access the numbers. This section does not prohibit the inclusion of the social security number on transcripts or on materials for Federal or State Data reporting requirements.

13.2.4.3 If an organizational unit must send materials containing social security numbers through the physical mail, the social security number must be placed in an envelope in such a way that ensures that no part of the social security number is visible from the outside.

13.2.4.4 U. T. Austin shall prohibit employees from sending social security numbers over the Internet or by email unless the connection is secure or the social security number is encrypted or otherwise secured. The Institution shall require employees sending social security numbers by fax to take appropriate measures to protect the confidentiality of the fax (such measures may include confirming with the recipient that the recipient is monitoring the fax machine).

13.2.4.5 U. T. Austin shall not print or permit a third-party acting on behalf of the Institution to require that an individual's social security number be printed on a card or other device required to access a product or service provided by, on behalf of, or through the Institution.

13.3 All Information Systems acquired or developed must comply with the following:

13.3.1 the Information System must use the social security number only as a Data element or alternate key to a database and not as a primary key to a database;

13.3.2 the Information System must not display social security numbers visually (such as on monitors, printed forms, system outputs) unless required or permitted by law or permitted by this Standard;

13.3.3 name and directory systems must be capable of being indexed or keyed on the unique identifier, once it is assigned, and not on the social security number; and

13.3.4 for those databases that require social security numbers, the databases may automatically cross-reference between the social security number and other Information through the use of conversion tables within the Information System or other technical mechanisms.

UT-IRUSP Standard 14: Information Services (IS) Privacy

Users who are University employees, including student employees, or who are otherwise serving as an agent or are working on behalf of the University have no expectation of privacy regarding any University Data they create, send, receive, or store on University-owned computers, Servers, or other Information Resources owned by, or held on behalf of, the University unless expressly stated by Regent's Rules. The U. T. Austin Information Security Office may access and monitor its Information Resources for any purpose consistent with the University's duties and/or mission without notice. They may also be accessed as needed for the purpose of system administration and maintenance; for resolution of technical problems; for compliance with the Texas Public Information Act; for compliance with Federal and State subpoenas, court orders, or other written authorizations; to conduct the business of the university; and to perform audits.

UT-IRUSP Standard 15: Passwords

15.1 Procedures. In order to preserve the security of U. T. Austin Information Resources and Data, Strong Passwords must be used to control access to Information Resources. All Passwords must be constructed, implemented, and maintained according to the requirements of the [U. T. System Identity Management Federation Member Operating Practices \(MOP\)](#) and applicable Policies, Standards, and/or Procedures governing Password management.

15.2 Strong passwords shall be used to control access to the university's Information Resources. All account passwords associated with the university's Information Resources must be constructed, implemented, and maintained according to the following, as technology permits:

15.2.1 Vetting User identity when issuing or resetting a password;

15.2.2 Account passwords must comply with the following password strength requirements:

15.2.2.1 Account passwords associated only with Controlled or Published Data must:

15.2.2.1.1 Be at least 9 characters in length; and

15.2.2.1.2 Be minimally composed of case sensitive letters and numbers.

15.2.2.2 Account passwords associated only with Controlled or Published Data must not:

15.2.2.2.1 Include personal information such as your name, phone number, social security number, date of birth, or addresses; or

15.2.2.2.2 Be composed of a single word found in a dictionary

15.2.2.3 Account passwords associated with Confidential Data shall inherit from 15.2.2.1 and must also:

15.2.2.3.1 Be at least 12 characters in length, with privileged account passwords being a minimum of 15 characters in length;

15.2.2.3.2 Contain case sensitive letters, numbers, and special characters (for example \! @ # \$ % & * () - + = < >)

15.2.2.4 Systems hosting Confidential Data must also be able to accommodate a reasonably long password length to support the use of longer passphrases.

15.2.2.5 Account passwords associated with Confidential Data must not:

15.2.2.5.1 Include personal information such as your name, phone number, social security number, date of birth, or addresses;

15.2.2.5.2 Be composed of a single word found in a dictionary;

15.2.2.5.3 Contain a series of the same character; or

15.2.2.5.4 Contain the user's account name or respective UT-EID.

15.2.3 All password change procedures must include the following:

15.2.3.1 Authentication of the user prior to changing the password (acceptable forms of authentication include answering a series of specific questions, showing one or more forms of photo ID, etc.).

15.2.3.2 The new password must comply with password strength requirements associated with the data classification for the service in question.

15.2.4 University identity credentials (security tokens, security certificates, smartcards, and other access and identification devices) must be disabled or returned to the appropriate department or entity on demand or upon termination of the relationship with the university. Additional operating guidelines for university ID cards are referenced in the [University Identification Card Guidelines](#) and the [Data Encryption Guidelines](#).

15.2.5 Unattended computing devices must be secured from unauthorized access using a combination of physical and logical security controls commensurate with associated risks. Physical security controls include barriers such as locked doors or security cables. Logical security controls include screen saver passwords and automatic session time-outs that are set to activate after 15-minutes of inactivity.

UT-IRUSP Standard 16: Data Center Security

16.1 Protection. All Information Resources must be physically protected based on Risk.

16.2 Safeguards. The university shall adopt safeguards to ensure appropriate granting, controlling, and monitoring of physical access. Physical access safeguards must incorporate Procedures for:

16.2.1 protecting facilities in proportion to the criticality or importance of their function and the confidentiality of any Information Resources affected;

16.2.2 managing access cards, badges, and/or keys;

16.2.3 granting, changing, and/or removing physical access to facilities to reflect changes in an individual's role or employment status; and

16.2.4 controlling visitor and Vendor physical access with Procedures that incorporate the following:

16.2.4.1 advanced scheduling, logging, and documenting of visits;

16.2.4.2 escorting while on premises; and

16.2.4.3 restricting the unauthorized use of photographic and video devices while on premises.

16.3 Central IT Managed Data Centers and U. T. System Shared Data Centers. In addition to the controls required in Standard 16.2, Data Centers managed by Institutional Central IT organizations and the U. T. System Shared Data Centers must incorporate procedures for each of the following:

16.3.1 reviewing physical access at least monthly, or more often if warranted by Risk;

16.3.2 designating staff who will have authorized access during an emergency;

16.3.3 monitoring the exterior and interior of the facility 24/7 by trained staff;

16.3.4 maintaining appropriate environmental controls such as alarms that monitor heat and humidity, fire suppression and detection systems supported by an independent energy source, and uninterruptible power systems capable of supporting all Computing Devices in the event of a primary power system failure, power surge protection devices, and anti-static measures where technically feasible; and

16.3.5 protecting any Shared or Central IT managed Data Center by implementing and maintaining the following:

16.3.5.1 security fencing, lighting, and landscaping to prevent concealment of intruders;

16.3.5.2 electronic alarms for all entry points into the facility and any internal areas housing critical infrastructure; and

16.3.5.3 computer rooms with no externally facing windows.

16.4 Decentralized IT Managed Data Centers. In addition to the controls required in Standard 16.2, the ISO shall develop Institutional Standards and safeguards to protect Decentralized IT Data Centers based on Risk.

16.4.1 The Physical Security Classification Standard (forthcoming) provides guidance as to how different areas of campus should be physically secured.

UT-IRUSP Standard 17: Security Monitoring.

17.1 At minimum, the U. T. Austin Chief Information Security Officer must ensure:

17.1.1 that network traffic and use of Information Resources is monitored as authorized by applicable law and only for purposes of fulfilling the university's mission related duty;

17.1.2 Server and network logs are reviewed manually or through automated processes on a scheduled basis based on Risk and regulation to ensure that Information Resources containing Confidential Data are not being inappropriately accessed;

17.1.3 vulnerability assessments are performed at least monthly, or more frequently commensurate with risk, and continuously where technically feasible, to identify software and configuration weaknesses within information systems;

17.1.4 an annual, professionally administered and reported external network penetration test is performed, leveraging peer institution resources, where possible;

17.1.5 that results of log reviews, vulnerability assessments, penetration tests, and IT audits are available to the ISO and that required remediation is implemented; and

17.1.6 all security monitoring shall be executed in accordance to the [Network Monitoring Guidelines](#).

UT-IRUSP Standard 18: Security Training

18.1 Initial and Recurring Training. The U. T. Austin Chief Information Security Officer shall ensure that security training is delivered and tracked. Initial and recurring training:

18.1.1 should, at minimum, identify User responsibilities, common threats, regulatory and Institutional requirements regarding the acceptable use and security of Information Resources, proper handling of Confidential Data, and incident notification; and

18.1.2 is to be administered in accordance with the following schedule, or more frequently as determined by an Institution.

18.1.2.1 Each new, temporary, contract, assigned, or engaged employee or worker must complete initial training within 30 days after the date that such a person is hired by the Institution or otherwise engaged or assigned to perform such work.

18.1.2.2 Recurring training for employees and workers with access to Institutional Information Resources shall take place annually in accordance with Texas Government Code Section 2054.5191.

18.2 In addition to initial training, users in security-relevant roles must receive role-based training addressing the responsibilities associated with their roles within 30 days of hire or role assignment, and at a frequency determined by the U. T. Austin Chief Information Security Officer based on risk.

18.3 Awareness Training should, at minimum, identify common threats, proper handling of Confidential Data, behaviors that increase Risk, behaviors that reduce Risk, and incident notification. Method of delivery and scheduling of awareness training should be determined by the U. T. Austin Chief Information Security Officer. Security training and awareness content must be reviewed and updated at least once every three years, or sooner following significant changes to applicable policies or regulations, emerging threats, or lessons learned from security incidents.

18.4 Technical Support Training. Owners and Custodians must provide, based on role, appropriate technical training equivalent to current industry standards for Information Security Administrators and employees providing Information Technology help-desk or technical support for Information Resources under their authority.

18.4.1 All Technical Support Staff (e.g., help desk, desktop support, server support) responsible for managing university owned IT devices are required to obtain an industry recognized certification, based on an IT training program defined by the Information Security Office working in conjunction with campus IT Governance, as a way of demonstrating professional skillset. Access to specific university IT tools and services will only be made available to professionally trained IT Support Staff.

18.4.1.1 IT Support Staff are expected to obtain and document continuing professional education credits each year as defined in the IT training program.

18.4.1.2 Certification exceptions will apply for IT Support Staff who have already clearly demonstrated mastery of necessary IT skills.

UT-IRUSP Standard 19: Server and Device Configuration and Management

19.1 Network Infrastructure Configuration. U. T. Austin must designate responsibility for the Institutional Network Infrastructure and specify those responsible for:

19.1.1 configuring and managing the resource in accordance with U. T. Austin information security Policies, Standards, and Procedures by:

19.1.1.1 segmenting the Institutional network either physically or logically to reduce the scope of exposure of Information Resources commensurate with the Risk and value of the Information Resource and Data; and

19.1.1.2 separating Internet-facing applications from internal applications;

19.1.2 maintaining appropriate access to the Network Infrastructure in accordance with U. T. System and Institutional information security Policies, Standards, and Procedures; and

19.1.3 managing, testing, and installing updates to operating systems and applications for network equipment under their responsibility, in accordance with the Minimum Security Standards for Mission Critical Systems.

19.2 Computing Devices. To protect against malicious attack, all Computing Devices on U. T. Austin networks will be security hardened based on Risk and must be administered according to Policies, Standards, and Procedures prescribed by U. T. Austin.

19.2.1 Mission Critical Computing Devices or Computing Devices containing Confidential Data must be identified and assigned to appropriately trained system administrators;

19.2.2 All Computing Devices (e.g., routers, laptops, tablets, desktops, and handheld devices) must be installed and maintained in accordance with the [Minimum Security Standards for Systems](#) to minimize service disruptions and prevent unauthorized access or use.

19.2.3 The Information Security Office shall provide specific [Hardening Checklists](#) for common operating system platforms and devices.

19.2.4 All endpoint devices (e.g., laptops, desktops, tablets) owned or managed by the university must follow this naming convention: <DEPTCODE>-<UTTAG#>-<optional-suffix>, as technology permits. For example: *ITSY-A34553* or *ITSY-A34553-username*.

19.3 Device Management. The U. T. Austin Chief Information Security Officer shall ensure that devices are administered by professionally trained staff in accordance with Policies, Standards, and Procedures prescribed by the Institution.

19.3.1 All endpoint devices (e.g., laptops, desktops, tablets) owned by the University must be managed by the centrally available Endpoint Management Platforms, unless an exception request has been approved by the U. T. Austin Information Security Office.

19.3.1.1 Personally owned or managed endpoint devices (e.g., laptops, desktops, tablets) processing any confidential or otherwise protected university data (e.g., FERPA, HIPAA, CUI, ITAR, NIST 800-53) are not authorized unless an exception request has first been approved by the local department head and finally by the U. T. Austin Information Security Office.

19.3.2 All Microsoft Windows servers owned by the University must be managed by the centrally available Microsoft Configuration Manager, unless an exception request has been approved by the U. T. Austin Information Security Office.

19.4 Access to Information Security Information and Devices. All Owners and Custodians of University owned, leased, or controlled Information Resources must provide the U. T. Austin Chief Information Security Officer with direct access to detailed security status Information including, but not restricted to the following: firewall rules, IPS/IDS rules, security configurations and patch status; and sufficient access rights to Servers and devices to independently and effectively execute the monitoring duties of the U. T. Austin Chief Information Security Officer.

19.5 All systems providing commodity services to university affiliates (e.g., web servers, mail servers, file servers, database servers, directory servers) must either be physically co-located within the University Data Centers, be virtualized within the ITS Virtualization service or be hosted in a sanctioned ITS managed cloud infrastructure.

19.5.1 The Information Security Office will work with Colleges, Schools, and Units to proactively identify all such qualifying systems.

19.5.2 Exceptions must be filed with the Information Security Office's [Exception Request Form](#) in cases where business, technical, or research needs require the system to be locally hosted. All exceptions must identify the business need for the exception and the

compensating controls that will be implemented to offset the risks associated with locally hosting the system. A single exception may be filed for a number of devices as long as the devices can be uniquely identified (e.g., UT Tag, Serial, MAC address).

19.6 All units are required to have their local IT Systems Custodian(s) participate in processing (e.g., inventory, standards verification, configuration) of all IT procurements (e.g., network-capable computing devices and [large dollar or high risk software](#)). This includes but is not limited to any university owned devices that have the ability to store university data or use the university wired or wireless networks. Examples of these types of computing devices include but are not limited to: laptops, desktop computers, tablet devices, and servers.

19.6.1 For units where central IT support contracts exist, the contracting entity will be required to provide the local IT Systems Custodian(s) with a complete inventory of computing devices for the contracted unit. The IT Systems Custodian(s) will perform these tasks in a timely manner so as not to delay distribution of the device to the end user.

19.6.2 All units creating purchase orders or pro-card transactions for IT procurements (e.g., network-capable computing devices and large dollar or high risk software) will ensure the IT Systems Custodian(s) are aware of the delivery destination.

19.6.2.1 The local IT Systems Custodian(s) will ensure the device is properly tagged for UT inventory and accounted for.

19.6.2.2 The local IT Systems Custodian(s) will enter the computing device into the University's centralized network-based registration tool and will configure it per policy requirements. All University and specific unit procedures for configuration will be applied including but not limited to encryption, system management tools, and strong user account passwords.

19.6.3 Department Heads or their designate may submit an [exception request](#) to this operational procedure in the event it would unnecessarily burden their unit.

UT-IRUSP Standard 20: Software Licensing

All software used on university computers will be used in accordance with the applicable software license. Unauthorized or unlicensed use

of software is regarded as a serious violation subject to disciplinary action and any such use is without the consent of the university.

20.1 The university will provide a sufficient number of cost-effective, licensed copies of core business software to enable faculty members, staff, and students to perform their work in an expedient and effective manner.

20.2 Systems administrators have the right to remove software from university computers for cause. For example, if a user is unable to show proof of license, or if the software is not required for university business purposes, or causes problems on the university-owned computer.

20.3 All departments or individuals managing university-owned computers will periodically audit all computers to inventory and document all installed software.

20.4 All departments are responsible for the accurate accounting of software purchased by the department and must ensure that the installation of the software complies with the license agreement of the software. For audit purposes, departments must maintain proof of purchase and/or original installation media for each software package.

UT-IRUSP Standard 21: System Development and Deployment

21.1 Information Security Consideration. U.T. Austin must adopt Institutional Policies, Standards and/or Procedures to ensure that the protection of Information Resources (including Data confidentiality, integrity, and availability) is considered during the development or purchase of new Information Systems or services.

21.2 Redundant Information Systems or Services. Information Systems that duplicate services provided by the U. T. Austin's Central IT organization are discouraged because they increase opportunity for exposure of Data. The Information Resources Manager shall approve the purchase or deployment of new Decentralized IT Information Systems or services (e.g., electronic mail/web/file servers, file/system backup, storage, etc.) that duplicate applications or services provided by Centralized IT. The Owner of the duplicative Information System and the IRM must document and justify exceptions based on business need, weighed against Risk of unauthorized access or loss of Data.

21.3 The university must ensure that the protection of Information Resources (including Data confidentiality, integrity, and accessibility) is considered during the development or purchase of new computer applications. The following procedures are required:

21.3.1 All associated systems and applications must restrict access and must provide methods for appropriately restricting privileges of authorized users. Access to applications is granted on a need-to-access basis.

21.3.1.1 All applications processing Confidential Data must comply with the [Minimum Security Standards for Application Development and Administration](#).

21.3.1.2 Separate production and test environments will be maintained to ensure the security and reliability of the central production system. Whenever possible, new development or modifications to a production system will be made first in a test environment. These changes should be thoroughly tested for valid functionality before being released to the production environment.

21.3.2 Information technology outsourcing contracts must address security, backup, and privacy requirements, and should include a right for U. T. Austin to conduct a security assessment or a right to review security assessments performed by third parties, or other provisions to provide appropriate assurances that applications and Data will be adequately protected when Confidential Data is associated. Vendors must adhere to all Federal and State laws and Regent's Rules pertaining to the protection of Information Resources and privacy of Confidential Data.

21.4 Security Review and Approval. The U. T. Austin Chief Information Security Officer must review and approve security requirements, specifications, and, if applicable, third-party Risk assessments for any new computer hardware, software, applications, or services that are Mission Critical or that receive, maintain, and/or share Confidential Data.

21.5 IT Systems Contracts. Contracts for purchase or development of automated systems that are associated with Confidential Data must address security, backup, and privacy requirements, and should include a right for U. T. Austin to conduct a security assessment or a right to review security assessments performed by third parties and other provisions to provide appropriate assurances that applications and Data will be adequately protected.

UT-IRUSP Standard 22: Vendor and Third-Party Controls and Compliance

U. T. Austin recognizes that Vendors and other contractors serve an important function in the development and/or support of services, hardware, and software and, in some cases, the operation of computer networks, Servers, and/or applications. This standard applies to contracts entered into by U. T. Austin that involves third-party access to or creation of Information Resources or University Data by a third-party.

22.1 Contracts. Contracts of any kind, including purchase orders, memoranda of understanding (MOU), letters of agreement, or any other type of legally binding agreement, that involve current or future third-party access to or creation of Information Resources and/or Data must include terms determined by the Office of General Counsel as sufficient to ensure that Vendors and any subcontractors or other third-parties that maintain, create, or access University Data as the result of the contract comply with all applicable Federal and State security and privacy laws, U. T. System 165, this Information Resources and Use Policy, and any applicable U. T. System and University Policies or Standards, and must contain terms that ensure that all University Data affected by the contract is maintained in accordance with those standards at all times, including post-termination of the contract. All contracts must be reviewed and executed by the UT [Business Contracts Office](#).

22.2 The Data Owner, U. T. Austin procurement officers and staff, and the U. T. Austin Chief Information Security Officer are jointly and separately responsible for ensuring that all contracts are reviewed to determine whether the contract involves third-party access to, outsourcing, maintenance, or creation of University Data; and that all such access, outsourcing, or maintenance fully complies with this Standard at all times.

22.3 Any contract involving third-party access to, creation, or maintenance of Protected Health Information (PHI) as defined in [45 C.F.R. § 164.501](#), must include a Health Insurance Portability and Accountability Act (HIPAA) business associate agreement in a form approved by U. T. Austin counsel or the U. T. System Office of General Counsel.

22.4 Any contract involving third-party-provided credit card services must require that the Contractor provides assurances that all

subcontractors who provide credit card services pursuant to the contract will comply with the requirements of the Payment Card Industry Data Security Standard (PCI DSS) in the provision of the services.

22.5 Vendor or other Third-Party Assessment. Prior to access, maintenance, or creation of University Data by a Vendor or any other third-party, the Institution must perform an assessment to ensure that:

22.5.1 the Vendor has sufficient technological, administrative, and physical safeguards to ensure the confidentiality, security, and Integrity of the Data at rest and during any transmission or transfer; and

22.5.2 any subcontractor or other third-party that will access, maintain, or create Data pursuant to the contract will also ensure the confidentiality, security, and Integrity of such Data while it is at rest and during any transmission or transfer; and

22.5.3 for cloud computing services that store, process, or transmit Confidential University Data, the vendor holds TX-RAMP certification through the Texas Department of Information Resources has been confirmed, where applicable, prior to entering or renewing a contract.

22.6 As part of the Institution's assessment of a Vendor or other third-party, the Institution will request copies of any self-assessments or third-party assessments that the Vendor or third-party has access to.

22.6.1 The Data Owner or their designate will be responsible for registering the service or vendor product and will record completed or updated Vendor or third-party assessments within [ISORA](#) the university risk management application and working with the Information Security Office to ensure vendor products comply with established [vendor security requirements](#).

22.7 Access Control Measures. Each Institution must control Vendor and other third-party access to its Data based on Data sensitivity and Risk. Controls must incorporate the following:

22.7.1 Vendor must represent, warrant, and certify it will:

22.7.1.1 hold all Confidential Data in the strictest confidence;

22.7.1.2 not release any Confidential Data unless Vendor obtains Institution's prior written approval and performs such a release in full

compliance with all applicable privacy laws, including the [Family Educational Rights and Privacy Act \(FERPA\)](#);

22.7.1.3 not otherwise use or disclose Confidential Data except as required or permitted by law;

22.7.1.4 safeguard Data according to all commercially reasonable administrative, physical, and technical Standards (e.g., such Standards established by the National Institute of Standards and Technology or the Center for Internet Security);

22.7.1.5 continually monitor its operations and take any action necessary to assure the Data is safeguarded in accordance with the terms of U. T. Austin Information Resources Use and Security Policy; and

22.7.1.6 comply with the Vendor access requirements that are set forth in this Standard.

22.8 Breach Notification. The following shall be required of the Vendor.

22.8.1 If an unauthorized use or disclosure of any Confidential Data occurs, the Vendor must provide:

22.8.1.1 written notice within one business day, or if The Data Owner, U. T. Austin procurement officers, and the U. T. Austin Chief Information Security Officer are satisfied that a longer period is acceptable, within that period, after Vendor's or third-party's discovery of such use or disclosure; and

22.8.1.2 all Information U. T. System requests concerning such unauthorized use or disclosure.

22.9 Return of Data. Within 30 days after the termination or expiration of a purchase order, contract, or agreement for any reason, Vendor must either:

22.9.1 return or securely destroy, as specified by contract or agreement, all Data provided to the Vendor by the Institution, including all Confidential Data provided to Vendor's employees, subcontractors, agents, or other affiliated persons or Institutions in accordance with applicable records retention requirements; or

22.9.2 in the event that returning or securely destroying the Data is infeasible, provide notification of the conditions that make return or destruction infeasible, in which case the Vendor or third-party must:

22.9.2.1 continue to protect all Data that it retains;

22.9.2.2 agree to limit further uses and disclosures of such Data to those purposes that make the return or destruction infeasible for as long as Vendor or other third-party maintains such Data; and

22.9.2.3 to the extent possible, de-identify such Data.

UT-IRUSP Standard 23: Security Control Exceptions

23.1 Exceptions to an otherwise required security control may be granted by the U. T. Austin Chief Information Security Officer to address specific circumstances or business needs, relating to an individual program or department, only as authorized by applicable law, and System and Institutional Policy. Requests for exceptions of this type must be submitted via the [Security Exception Form](#) and should be initiated by the Data Owner. Both the U. T. Austin Chief Information Security Officer and Data Owner are jointly responsible for ensuring that any exception is not contrary to applicable law.

23.2 The U. T. Austin Chief Information Security Officer may issue blanket exceptions to address Institution-wide situations.

23.3 All exceptions must be based on an assessment of business requirements weighed against the likelihood of an unauthorized exposure, and the potential adverse consequences for individuals, other organizations, or the Institution were an exposure to occur.

23.4 As a condition for granting an exception, the U. T. Austin Chief Information Security Officer may require compensating controls be implemented to offset the risk.

23.5 All exceptions must be documented, and must include the following elements:

23.5.1 a statement defining the nature and scope of the exception in terms of the Data included and/or the class of devices included;

23.5.2 the rationale for granting the exception;

23.5.3 an expiration date for the exception;

23.5.4 a description of any compensating security measures that are to be required; and

23.5.5 acknowledgement, via signature (written, electronic, or through automated process), of the U. T. Austin Chief Information Security Officer, and, in the case of an exception resulting from a Data Owner request, of the Data Owner.

23.6 Encryption Exceptions.

23.6.1 The U. T. Austin Chief Information Security Officer may grant an exception to the use of encryption on a device if it is determined that encryption makes the device unsuitable to perform its intended functions, there are no alternative hardware or software options available that can be used to allow encryption, and the Risk posed by the unencrypted device is minimal or moderate based on its use and/or other implemented compensating controls.

23.6.2 The U. T. Austin Chief Information Security Officer may recommend to the Chief Administrative Officer an encryption exception be granted for a High Impact Device if encryption makes the device unsuitable to perform its intended function. Exception recommendations have the effect of being approved unless, upon review, the Chief Administrative Officer disapproves the recommendation.

23.7 A summary of exceptions and exception recommendations shall be reported to the President in the annual Presidential Information Security Program Report with sufficient detail to provide the President with an understanding of types of Risks and level of Institutional exposure.

23.8 This standard does not apply to or authorize the U. T. Austin Chief Information Security Officer ISO to grant exceptions to [UT-IRUSP Standard 2: Acceptable Use of Information Resources](#).

UT-IRUSP Standard 24: Disciplinary Actions

Violation of this Policy or other U. T. System or U. T. Austin Information Security Policies or Standards by university affiliates who have access to U. T. Austin Information Resources or Data for the purpose of providing services to or on behalf of an Institution, are subject to disciplinary action in accordance with the applicable Institutional rules and Policies. Some violations may include the termination of access to the respective service. For contractors and consultants, this may include termination of the work engagement and execution of penalties contained in the work contract. For interns and

volunteers, this may include dismissal. Additionally, certain violations may result in civil action or referral for criminal prosecution.

24.1 It is not the role of Information Technology professionals to carry out disciplinary actions as the result of an incident, but it is their role to monitor resources, to identify potential incidents, and to bring such incidents to the attention of appropriate university officials. The following guidelines apply:

24.1.1 Suspected incidents involving university affiliate misuse of Information Resources should be brought to the attention of the Information Security Office.

24.1.2 If an investigation involving review of the content of a university affiliate's files is required, written permission will be obtained from the Office of Legal Affairs and other departments, as necessary.

24.1.3 If it is determined that a misuse violation has occurred by a university affiliate, the incident should be brought to the attention of the Information Security Office. The Information Security Office will consult with the Office of Legal Affairs, Human Resource Services, or Student Judicial Services, as needed, and in the case of criminal violations, the University Police Department.

24.1.4 Violations by non-affiliates will be referred to the appropriate authorities. The Office of Legal Affairs may be contacted to provide direction in terms of identifying the appropriate authority.

Revision History

Version	Date	New	Original
	6/25/2026	Expanded 22.9.1 to require vendor data return or destruction to comply with applicable records retention requirements.	Expanded
	6/25/2026	Added 22.5.3 to require TX-RAMP certification confirmation for cloud services that store, process, or transmit Confidential University	New

Version	Date	New	Original
		Data prior to entering or renewing a contract.	
	6/24/2026	Expanded 10.4 to require risk assessment results be documented in a written report ranked by risk level; expanded 16.3.4 to include power surge protection devices and anti-static measures in the environmental controls requirements; expanded 17.1.3 to update the vulnerability assessment cadence from annually to at least monthly, with continuous scanning where technically feasible; expanded 18.2 to broaden role-based training to all security-relevant roles, strengthen the requirement from "should" to "must," and add a 30-day onboarding deadline with CISO-determined recurring frequency; and expanded 18.3 to require security training and awareness content be reviewed and updated at least every three years, or sooner following policy changes, emerging threats, or lessons learned from incidents.	Expanded
	6/24/2026	Updated 6.2.3 to change the disaster recovery plan testing cadence from	Updated

Version	Date	New	Original
		every two years to annually.	
	6/24/2026	Added 3.5 through 3.7 to formalize information security documentation review, DIR compliance assessment, and DIR Information Security Plan requirements; added 8.2.1 to prohibit disabling anti-malware software and require real-time and email scanning; and added 11.7.3 to require sanitization of assets that have stored Confidential Data prior to transfer or reuse.	New
	6/22/2026	Added 2.3.1.5 restricting the use of university-provided credentials on external sites and prohibit posting organizational data on public websites or social media.	New
	6/22/2026	Expanded 1.7.26 to describe annual reporting requirements and reference TAC 202 compliance.	Expanded
	6/11/2026	Added definition of Heightened Scrutiny Artificial Intelligence System (HSAI) and new 11.9 through 11.9.4.3 establishing AI data classification requirements, approved tools governance, disclosure obligations	New

Version	Date	New	Original
		under SB 1964, and HSAI oversight requirements.	
	5/5/2025	Protected Users Group requirement added to requirement 5.1.2	New - Due to Internal Audit finding
	3/5/2025	Added compliance requirement for Prohibited Technology and Covered Applications to the Acceptable Use Policy language.	New
	01/29/2024	Added 4.6.1.1 in response to audit findings and added definition for "Mission Critical Information Resources Staff".	New
	11/18/2023	Added 19.3.2 requiring Windows servers to be managed via centrally available Configuration Manager service after audit finding and executive leadership mandate.	New
	11/13/2023	Added 5.1.1, 5.1.2, 19.2.4 in response to audit findings.	New
	6/27/2023	Clarified case sensitivity inheritance for 15.2.2.3	Clarified based on Internal Audit finding
	4/19/2022	Updated the IRM responsibilities (Sec 1.4) and Personally Owned Device compliance (Sec 8.1 through 8.3) per UT System Board of Regents mandated changes for all UT campuses.	Expanded and Updated

Version	Date	New	Original
	4/14/2022	Established 19.3.1 for endpoint management based on audit finding and executive leadership mandate.	New
	5/15/2021	Clarified 22.6.1 requiring Data Owners to registered vendor services or products	Clarified based on Internal Audit finding
	5/16/2020	Added expanded requirement for multi-factor authentication.	Expanded
	4/20/2020	Updated Vendor risk management details (Sec 22) to align with state requirements.	Updated
	6/11/2018	Added 4.6.4 two-factor requirement for web based email to align with U. T. System UTS 165 change.	New
	7/6/2015	Aligned U. T. Austin IRUSP with U. T. System UTS 165, which was significantly revised. All unique standalone policy statements were carried forward as long as they did not otherwise conflict with UTS 165. Other supplemental documents used by the U. T. Austin IRUSP will also need to be updated accordingly.	New
	9/10/2014	Policy changes were requested by the Internal Audit Committee and endorsed by IT Governance and the	New

Version	Date	New	Original
Information Resources Use and Security Policy		Executive Compliance Committee. These sections were added or updated based on the approved policy changes (5.4.1, 5.4.5, 5.4.7, 5.22.3, and 5.23.5).	
	1/6/2014	Added Section 5.23.3 regarding commodity servers. This policy change was endorsed by IT Governance and finally approved by the Executive Compliance Committee.	New
	6/24/2013	Reviewed and fixed broken links.	
	6/18/2013	Converted back to HTML.	
	6/27/2011	Section 5.2.2: ILFIILFI This section to be made effective on December 31, 2011 so as to allow the campus time to transition to the new encryption solutionIRFIIRFI.	Section 5.2.2: ILFIILFI This section to be made effective on June 20, 2011 so as to allow the campus time to transition to the new encryption solutionIRFIIRFI.
	2/25/2011	Converted web page to PDF	No changes
	2/9/2011	Clarified language to bring consistency across policies and standards regarding systems that store, process, or transmit sensitive data, as well as with industry standards and	8.1. All data owners, data stewards, or designated custodians, shall be responsible for classifying Digital Data processed by systems under their purview based on

Version	Date	New	Original
		government regulations such as PCI and HIPAA.	data sensitivity and risk so that th appropriate security controls can be applied. 11.1. The Minimum Security Standards for Systems describe and require appropriate steps to protect Category-I Digital Data (for example, social security numbers, protected health information, sensitive research data, digital data associated with an individual and/or digital data protected by law) stored on the university's computing devices. 11.3.3. Unless otherwise required by federal or state law or regulation, Category-I Digital Data must not be stored on university or non-university owned computers or other electronic devices (for example, laptop, hand-held device, Flash drive, or other

Version	Date	New	Original
			portable computing devices) unless:
	12/15/2010	After being approved by IT Governance, the Internal Audit Committee, and the President, Section 5.20.2 of the IRUSP was modified to require encryption of all university-owned laptops regardless of their data classification. The policy also now references the Information Security Office's approved encryption methods. ILFIILFI This change to be made effective on June 20, 2011 so as to allow the campus time to transition to the new encryption solution IRFIIRFI	20.2. All university and non-university owned portable computing devices storing Category-I university data must also comply with UT System Security Practice Bulletin #1 (SPB-1).
	8/29/2008	Document republished in new HTML format. Removed compliance dates from sections 8 and 22 as those requirements have been met. In section 5, moved information on auditing the backup and recovery plans	Old format was PDF. To receive copies of the archived PDF format, please contact the Information Security Office.

Version	Date	New	Original
		to sections 5.1 and 5.2 respectively.	
		Updated all references to the university to conform to the University Style Guide.	
	11/10/2007	New version published to comply with UTS-165. Major changes in this version are: • Title changed from IT Security Operations Manual to Information Resources Use and Security Policy to better align with U. T. System UTS-165, which consolidated BPM-53, BPM-66, and BPM-75. The structure of the document has also been changed to better track with UTS-165. • Planned to be added to Handbook of Operating Procedures. • Added roles and responsibilities for university IT resources (Sec 1). • Formalized data classification	To receive copies of the archived IT Security Operations Manual, please contact the Information Security Office.

Version	Date	New	Original
		requirements (Sec 8). - Added Risk Management section (Sec 9). - Added Management of Sensitive Data (Sec 11). - Extended specific network responsibilities (e.g., cabling, wireless signaling) to ITS Networking group to ensure operational availability and compatibility. - Added specific training requirements for all IT support staff (Sec 20).	
	4/5/2007	Added links to newly published, approved supplemental standards and guidelines: - Section 5.23: Minimum Security Standards for Application Development and Administration. - Section 5.26: Minimum Security Standards for Data Stewardship	Previously noted that documents were forthcoming.
	4/5/2007	Fixed typo in section 5.26, #4.	"Ensure appropriate backup and retention of

Version	Date	New	Original
		"Ensure appropriate backup and retention of that data."	that data, and"
	3/28/2007	Changed references from "ITS Telecommunications and Networking" to "ITS Networking."	"ITS Telecommunications and Networking."
		Changed reference in section 5.6 from "Data Classification Guidelines" to "Data Classification Standard" to reflect correct document title.	"Data Classification Guidelines"
		Corrected typo in section 5.12.3	"Tthe University"...
	11/20/2006	Changed references from "Data Classification Guidelines" to "Data Classification Standard" to reflect correct document title.	"Data Classification Guidelines"
	10/20/2006	Numbered individual standards within each category for easier reference.	New.
	10/20/2006	Section 5.12.5, replaced "Information Technology Services" with	"All confidential, personally identifiable, protected health information, certain

Version	Date	New	Original
		Information Security Office."	financial data, or certain student data transmitted over any network must be encrypted in accordance with Data Classification Guidelines published by Information Technology Services."
	10/20/2006	Section 5.14, replaced "ITS" with Information Security Office."	To ensure compatibility with The University of Texas at Austin network, all computers, PDAs and office productivity software purchased by The University of Texas at Austin should adhere to system standards endorsed by ITS.
	10/20/2006	Section 5.15.3, moved bullet 3 to follow the bulleted list.	"All registered hosts attached to the university network may be scanned by the Information Security Office for potential vulnerabilities." incorrectly appeared within bulleted list.
	10/20/2006	Corrected an indentation problem in Section 5.16.	"All remote users must comply with the Minimum Security Standards for Systems as published by Information Technology Services."
	10/20/2006	In Section 5.19.6, removed "ITS" from sentence.	"Any security issues discovered will be reported to the ITS Information Security Office and appropriate executive officials (see Section 5.25)."

Version	Date	New	Original
	10/20/2006	Section 5.20, Replaced "Information Technology Services" with Information Security Office" where appropriate. Removed "(training to be arranged by Information Technology Services)." Security awareness training has been developed by the Information Security Office and is now available through the Compliance Office.	"Recurring security awareness training for all faculty and staff will be offered annually (training to be arranged by Information Technology Services)."
	10/20/2006	In Section 5.20.7, removed "ITS" from sentence.	"The ITS Information Security Office is responsible for communicating new issues or vulnerabilities to vendors as needed, and for working with the vendors to eliminate or mitigate the vulnerabilities."
	10/20/2006	Changed the title of Section 5.23 to "Secure Development and Administration."	"Enterprise Development and Deployment."
	10/20/2006	Section 5.24, reworded subsections 4.a, 4.e, and 4f to make more clear.	• The University of Texas at Austin information the vendor may access. • The University of Texas at Austin, or respective department, right to audit and otherwise verify the security of university

Version	Date	New	Original
			information and other resources in the possession of or being managed by the vendor and the university's right to investigate any security breaches involving these resources. • The University of Texas at Austin, or respective department, right to require background checks for vendors working with security sensitive university information.
	10/20/2006	Corrected typo in section 5.25.3.	"If it is determined that a misuse violation has occurred by a student, faculty, or staff member, this should be brought to the attention of the Information Security Office. The Information Security Office with consult with either the Human Resource Services or Student Judicial Services, as needed, and in the case of criminal violations, the University Police Department."
	10/20/2006	Added Section 5.26, "Sensitive Data Classification."	New.

Version	Date	New	Original
	7/11/2006	Changed title to "IT Security Operations Manual" in this and all documents referencing the title.	"Information Technology Resources Security Operations Manual."
	5/2/2006	Sec. 18: Added link to Minimum Security Standards for Systems.	"All remote users must comply with the Minimum Security Standards for Desktop and Portable Computing as published by Information Technology Services (forthcoming)."
	3/13/2006	Changed reference from System Hardening Procedure to "Minimum Security Standards for Systems."	"System Hardening Procedure"
	2/20/2006	Added link to Security Exception Request form.	"(forthcoming)"
	1/20/2006	Removed inline glossary and referred to ISO Technical and Security Glossary and Usage Guide.	None.
		Various corrections to language errors, acronym use, and references.	
		Added "Last reviewed" and "Last updated" dates.	

Version	Date	New	Original
		Added links to newly published supporting documents.	
	12/13/2005	Sec. 25: Added "Issues of departmental non-compliance may be reported to the respective executive management, the Office of Internal Audit, or the Office of the President."	None.
	12/13/2005	Sec. 7, paragraph 1: Added "The following change management procedures are required in proportion to the respective data classification category, the availability requirements of the data, and the impact of the change on the user community:"	"The following change management procedures are required:"
	10/31/2005	Sec. 5: Corrected form name to "Security Sensitive" form, per ISO office.	"Position of Special Trust form."

Revision History



Information Security Office

Copyright © 2006–2026, Information Security Office. All rights reserved.

[Privacy Policy](#) | [Accessibility Policy](#)

